

Received 13 July 2024, accepted 4 August 2024, date of publication 12 August 2024, date of current version 22 August 2024.

Digital Object Identifier 10.1109/ACCESS.2024.3441751

RESEARCH ARTICLE

Design a Software Reference Architecture to Enhance Privacy and Security in Electronic Health Records

RODRIGO TERTULINO^{1,2}, NAGHMEH IVAKI¹, (Member, IEEE), AND HIGOR MORAIS²

¹Centre for Informatics and Systems of the University of Coimbra (CISUC), Department of Informatics Engineering, University of Coimbra, 3030-290 Coimbra, Portugal

²Federal Institute of Education, Science, and Technology of Rio Grande do Norte (IFRN), Natal 59628-330, Brazil

Corresponding author: Rodrigo Tertulino (rrsilva@dei.uc.pt)

This work was supported in part by the Project “Agenda Mobilizadora Sines Nexus” ref. No. 7113, funded by the Recovery and Resilience Plan (PRR) under Project UIDP/00326/2020; in part by European Funds Next Generation EU through Component 5-Capitalization and Business Innovation-Mobilizing Agendas for Business Innovation under Grant 02/C05-i01/2022; and in part by the FCT-Foundation for Science and Technology, I.P./Ministério da Ciência, Tecnologia e Ensino Superior (MCTES) through National Funds [Plano de Investimentos e Despesas de Desenvolvimento da Administração Central (PIDDAC)], within the scope of Centre for Informatics and Systems of the University of Coimbra (CISUC) Research and Development Unit under Grant UIDB/00326/2020.

ABSTRACT Healthcare services and organizations rely on Electronic Health Records (EHRs) to manage, store, and transmit patient data records. Consequently, EHRs play a crucial role in providing high-quality services and maintaining the privacy and security of patients’ sensitive data. However, designing such complex systems with security and privacy concerns is anything but simple. This study aims to propose a Software Reference Architecture (SRA) tailored for Electronic Health Records (EHRs) with security and privacy considerations, intending to enhance the development of these systems. To achieve this goal, we analyze the classification of Reference Architectures (RAs), taking into account the primary security and privacy requirements of EHRs along with well-established architectural design methods. We propose a layered architecture for SRA with privacy and security considerations. Subsequently, we derive the following five architecture views for SRA: the feature diagram, the context diagram, the decomposition view, the layered view, and the deployment view. Each view showcases the SRA software architecture from a different perspective. Moreover, we conducted an evaluation of the proposed SRA through its application in a case study. Specifically, we applied the proposed SRA and derived the application architecture from a study focused on Brazilian EHRs. Our analysis highlights the potential issues arising from the absence of an SRA tailored for EHRs, particularly regarding privacy and security concerns surrounding patient data. Through this case study, we demonstrate the practical applicability of our proposed SRA in enhancing EHR systems.

INDEX TERMS Healthcare systems, electronic health record (EHR), privacy, security, software reference architecture (SRA).

I. INTRODUCTION

According to ISO/TR 20514:2005 [1], Electronic Health Records (EHRs) can be defined as a repository storing patients’ historical, concurrent, and forthcoming data in a digital format that can be accessed by multiple authorized users and can be exchanged seamlessly and securely,

The associate editor coordinating the review of this manuscript and approving it for publication was Peter Langendoerfer^{1b}.

supporting continuous, efficient and high-quality integrated healthcare [2].

The primary concern in such integrated healthcare systems, which aim to provide seamless and transparent doctor-patient relationships, is ensuring the delivery of high-quality and effective treatment. This necessitates patients to frequently share private and sensitive information such as medication details, progress reports, vital signs, medical history, immunization records, laboratory data, and radiology results

with their healthcare providers. However, sometimes, they may refuse to reveal their sensitive information that, when disclosed, may result in social disapproval and discrimination [3], representing a significant challenge in the successful development of EHR systems [4]. Thus, privacy and data security must be paramount considerations in EHR system design. However, in the relationship between healthcare providers and healthcare receivers, privacy has always been a secondary concern despite its critical importance.

The idea of Electronic Health Record (EHR) was first developed and used in 1992 [5]. Since then, they have seen increasing adoption among patients, hospitals, doctors, and other health professionals [6] as they bring several advantages, including reduced healthcare costs and improved accessibility to health records [7]. On the other hand, using EHRs raised significant concerns about patient records' security (e.g., integrity) and privacy [8]. These concerns affect patients' interest in disclosing their health data, which can have severe consequences. For instance, the United States Department of Health and Human Services (HHS) estimated that approximately two million Americans with mental illness did not seek treatment precisely because of privacy concerns [9]. Hence, nowadays, the widespread acceptance and adoption of EHRs have been significantly influenced by concerns regarding privacy and security [5], [10], necessitating solutions that effectively address these issues to facilitate the successful adoption of EHR systems.

In this paper, **our objective is to introduce a Software Reference Architecture (SRA) for EHR systems, with a particular focus on addressing data security and privacy concerns.** Software Reference Architecture (SRA) acts as a fundamental yet abstract and generic architecture for designing and building a class of systems, especially for organizations that are heavily dependent on efficiently developing and maintaining complex and critical (i.e., business-critical or safety-critical) software systems such as healthcare systems [11].

While various SRAs exist in the literature, offering reference architectures for healthcare systems [12], [13], they are often tailored to specific contexts, such as IoT [14], or ignore crucial aspects of privacy and security in their designs [15]. To the best of our knowledge, there is currently no SRA specifically tailored for EHR systems that comprehensively addresses privacy and security concerns. Therefore, this paper seeks to answer the following questions: i) How to constitute a viable Software Reference Architecture (SRA) for Electronic Health Records (EHRs) that systematically integrates privacy and security considerations? and ii) Is an SRA centered on privacy and security a viable strategy for tackling the challenges associated with ensuring the security and privacy of these systems?

The remainder of this article is organized as follows: Section II discusses previous research and studies on privacy and security requirements, privacy by design, and RAs in healthcare and EHRs. Section III presents the approach and methodology for building our SRA. Section IV describes the

SRA proposed for EHRs to enhance privacy and security. Section V presents the SRA evaluation. Section VI discusses the answers to our research questions. Finally, Section VII concludes the research and highlights the direction for future work.

II. BACKGROUND AND RELATED WORK

This section of the paper discusses previous research and studies on i) Privacy by Design methodologies, ii) Identifying privacy and security requirements for EHRs, and iii) Software reference architectures for EHRs or Healthcare Systems. This section provides an overview of the existing literature on these topics and highlights the gaps in the current research that the present study aims to address.

A. PRIVACY BY DESIGN METHODOLOGIES

Several methodologies have been proposed in the literature to proactively incorporate privacy requirements into the system design process.

The **Privacy Safeguard Methodology (PriS)** [16], proposed in 2005, introduces a collection of concepts aimed at translating privacy requirements into organizational goals during the system design phase. Additionally, it establishes a systematic approach for analyzing the impact of privacy objectives on organizational processes.

The concept of **Privacy by Design** was initially introduced in the 1990s by data privacy expert Ann Cavoukian [17]. Privacy by Design aims to incorporate privacy and protection of personal data from the beginning of developing products, services, projects, processes, practices, technologies, and infrastructures.

Later, in 2009, the Privacy by Design (PbD) framework with seven fundamental principles was published [18]. These principals include i) Proactive, not reactive, ii) Privacy as the default setting, iii) Privacy embedded into the design, iv) Full functionality, v) End-to-end security (i.e., complete life-cycle protection), vi) Visibility and transparency, and vii) Respect for user privacy. PbD aims to safeguard privacy and empower individuals to retain control over their information, resulting in a sustainable competitive advantage for organizations [19].

The Privacy Safeguard Methodology (PriS) and Privacy by Design (PbD) methodologies, while valuable in addressing privacy concerns, have limitations.

PriS, despite offering a structured approach, faces challenges in practical implementation due to its complexity. Analyzing privacy objectives and translating them into organizational goals can be resource-intensive and may require specialized expertise. Additionally, PriS may struggle to adapt quickly to evolving privacy regulations and technological advancements, potentially rendering it less effective in dynamically changing environments.

On the other hand, PbD's comprehensive principles for integrating privacy into organizational practices encounter practical hurdles. Implementing PbD's principles across all aspects of product development can be challenging, especially if privacy considerations have not been prioritized

since the project's inception. Moreover, achieving a cultural shift within organizations to prioritize privacy as a core value may meet resistance and require significant time and effort. Additionally, while PbD aims to ensure privacy compliance, it may not perfectly align with all regulatory requirements in different jurisdictions, necessitating supplementary measures to ensure full compliance.

Despite these limitations, both methodologies are valuable frameworks for addressing privacy concerns in system design and development. They provide organizations with strategies to navigate the complex landscape of privacy regulations and consumer expectations, albeit with some practical challenges.

B. EHRs' PRIVACY AND SECURITY REQUIREMENTS

Ensuring the privacy and security of electronic health records (EHRs) is paramount in modern healthcare to protect patient data and maintain service integrity. This section reviews the studies identifying security and privacy requirements for healthcare and EHR systems. To identify the requirements list, we analyzed various works in the literature that aimed to identify security and privacy requirements in healthcare systems. Table 1 highlights the strengths and weaknesses of each article and enumerates the requirements identified or emphasized by each.

According to the literature, as summarized in Table 1, essential security and privacy requirements include **Access Control, Confidentiality, Privacy, Consent, Anonymization, Integrity Maintenance, Audit Controls, Emergency Access, Secure Transmission, Availability, and Automatic Logoff**.

Access control, which includes **Authentication, Authorization, and Non-repudiation**, ensures that only authorized users can access data and prevents denial of participation in actions such as altering patient information or accessing private data. While Confidentiality ensures the protection of sensitive data from unauthorized access (or disclosure or use), Privacy ensures the individuals' right to control access to their personal information. Consent ensures that patient preferences are respected. Anonymization ensures that personal information is removed from or modified within a dataset so that the data can no longer be attributed to a specific individual, thereby helping preserve privacy. Integrity maintenance guarantees data accuracy, and Audit Controls monitor system activities. Emergency access enables rapid data retrieval, and Availability guarantees continuous data access for authorized users, even during failures or attacks. Secure Transmission prevents breaches, and Automatic logoff mitigates unauthorized access risks. By adhering to these requirements, healthcare organizations can maintain patient confidentiality, data integrity, and regulatory compliance in EHR systems, fostering trust and efficiency in healthcare delivery.

C. SRAs FOR EHRs AND HEALTHCARE SYSTEMS

This section examines studies proposing software reference architectures tailored to Electronic Health Record (EHR)

systems. By reviewing these studies, the aim is to gain insights into the architectural frameworks and design principles that underpin effective EHR systems. This analysis is crucial for understanding the complexities inherent in EHR development and identifying common patterns and best practices to inform the design of robust and interoperable EHR solutions. Through this review, the section aims to advance EHR system design by synthesizing existing research and identifying gaps or areas for further investigation.

The work presented in [13] outlines vital objectives and features of a reference architecture designed to enhance e-health applications. Central to this architecture is the goal of enabling personalized experiences for users through AI algorithms and user data, facilitating tailored services and recommendations that align with individual preferences and health objectives, thereby fostering heightened user engagement. Additionally, the architecture aims to support self-adaptation by dynamically adjusting services based on real-time data from IoT devices and user interactions, ensuring responsiveness to evolving user contexts and environmental factors. Critical to the success of these endeavors is the implementation of robust data security and privacy measures, including encryption algorithms and secure deployment options, which protect user data against unauthorized access and breaches, thereby fostering trust and compliance with privacy regulations. The overarching aim of emphasizing personalization, self-adaptation, and data security within the reference architecture is to elevate the overall user experience, engagement, and effectiveness of e-health applications, aligning with contemporary user expectations and needs in the digital health domain.

Another work presented in [14] also highlights the transformative potential of IoT technology in healthcare, citing its capacity to drive cost reductions and enhance health outcomes through the deployment of distributed applications. It delineates the multifaceted challenges encountered in developing and implementing IoT-based healthcare solutions, including interoperability, availability, usability, and security issues exacerbated by the heterogeneous nature of IoT systems. In response to these challenges, the paper advocates adopting a software reference architecture, termed Reference Architecture for Healthcare (RAH), designed to systematically organize the core components, responsibilities, and interactions within IoT-based healthcare applications. RAH is positioned as a solution to foster mutual understanding among stakeholders, mitigate development expenses, bolster interoperability, and fortify system reliability and security. The paper makes a significant scholarly contribution by proposing a structured approach to architectural design for IoT healthcare applications while suggesting avenues for future research to validate and refine the proposed architecture.

The work presented in [15] proposes a reference architecture design for computer-based speech therapy systems, emphasizing the importance of a structured approach in their development. This reference architecture is a blueprint

TABLE 1. Related works on security and privacy requirements.

Ref.	Description	Requirements
[20]	This work focuses on the security requirements of integrated PHRs, which combine EHR information from institutional medical records with patient self-reported data. The authors conducted a literature review and used the Delphi technique to identify seven dimensions of integrated PHR security requirements. While strong in identifying requirements, the study lacks a reference model for enhancing security and privacy implementation.	Confidentiality, Integrity, Authorization, Access Right, Availability, Authentication, Non-repudiation,
[21]	This work presents a Blockchain-Based Framework for Interoperable EHR, enhancing healthcare system sustainability. The framework ensures secure, transparent, and decentralized data sharing among providers, prioritizing patient privacy and data integrity. It enables interoperability across various data formats and protocols, facilitating efficient patient care and cost reduction.	Confidentiality, Privacy, Integrity, Secure Sharing and Storage
[22]	This study highlights the need for implementing privacy and security measures in EHR technology to address the challenges faced by healthcare organizations in safeguarding sensitive patient information. The paper analyzed different security and privacy issues arising from using EHRs. However, it does not provide specific recommendations for healthcare organizations to implement privacy and security measures in EHR technology.	Confidentiality, Integrity, and Availability
[23]	The authors provide valuable insights into the challenges and limitations of implementing attribute-based access control (ABAC) in healthcare settings and offer recommendations for future research. However, the article could benefit from more concrete examples of how ABAC has been implemented in real-world healthcare organizations and its impact on security practices.	Access Control
[24]	The article developed a privacy management framework (PMF) to protect personal information in Personal EHR (PEHRs) accessed on a mobile device. The PMF consists of three tiers: The first tier leads the PMF integration through laws, privacy policies, and procedures. The second tier comprises two main support pillars: operational privacy and audit and review. The last tier functions as the PMF's foundation, managing awareness, training, communications, and support for healthcare institutions and patients.	Access Control, Confidentiality, Traceability, and Integrity
[25]	The article introduces an authentication framework and a hybrid model for Personally Controlled Electronic Health Record (PCEHR) access control, utilizing cryptography to safeguard patient EHRs. While the proposed authentication model integrates multichannel authentication and context restriction with conventional access control models, it lacks a thorough efficiency and privacy analysis compared to existing solutions. Furthermore, the article does not discuss the potential challenges and limitations of implementing the proposed model in real-world e-health systems.	Access Control
[26]	This paper aims to elaborate on security threats and attacks within healthcare systems. It underscores critical security measures like authentication, confidentiality, integrity, availability, non-repudiation, and privacy, which are indispensable. However, it does not suggest mitigation strategies for these attacks.	Authentication, Confidentiality, Integrity, Availability, and Non-Repudiation
[27]	This paper provides an overview of the key security and privacy requirements in the context of Electronic Health Records (EHRs) and discusses the legal and ethical aspects, such as consent and data ownership, that should be considered when implementing EHRs.	Availability, Confidentiality, Privacy, Integrity, Authentication, Authorization, Non-repudiation
[27]	This article analyzes the current research on security and privacy requirements in EHR systems and identifies the existing solutions for these requirements and potential research gaps in the literature.	Access Control, Emergency access, De-identification, Audit control, Integrity, Secure transmission, Authentication, Consent, Encryption and decryption, Automatic Logoff

for guiding system development and analysis by capturing reusable design elements specific to Online Speech Therapy Systems (OSTS) and aligning with software architecture documentation guidelines. The authors also highlight functional and quality concerns in OSTs development. Functional concerns include speech assessment, tailored therapy exercises, progress tracking, feedback mechanisms, user engagement, and data analysis capabilities. Quality concerns include security, reliability, scalability, usability, performance, accessibility, and interoperability. By addressing these concerns within the context of the reference architecture, developers can create robust and effective OSTs that meet the needs of speech therapists and users while ensuring data security, system reliability, and user satisfaction.

In [12], the authors systematically analyze the complex landscape of EHR systems, emphasizing the need for interoperability, data exchange standards, scalability, and security. From extensive literature reviews and expert consultations, they outline the key components and functionalities essential for an effective EHR system. The proposed reference architecture provides a structured framework for organizing these components, defining their interactions, and facilitating seamless integration with existing healthcare infrastructure. By establishing a shared understanding and set of principles, the reference architecture aims to streamline the design, development, and deployment of EHR systems while addressing the challenges of interoperability and system complexity prevalent in the healthcare domain.

The section presents a comprehensive analysis of studies identifying software reference architectures tailored specifically for Electronic Health Record (EHR) systems, e-health applications, computer-based speech therapy systems, and IoT-based healthcare applications. Each study underscores the importance of a structured approach in addressing the complexities inherent in healthcare technology development. For instance, the study on e-health applications emphasizes the significance of personalized experiences enabled by AI algorithms and user data, alongside self-adaptation capabilities and robust data security measures. Similarly, the research on IoT-based healthcare applications advocates for a Reference Architecture for Healthcare (RAH) to foster interoperability, mitigate development costs, and enhance system reliability and security. Meanwhile, the study on computer-based speech therapy systems highlights functional and quality concerns, proposing a reference architecture to guide the development of effective online speech therapy systems while ensuring data security and user satisfaction. Lastly, examining EHR systems emphasizes the need for interoperability, scalability, and security, proposing a reference architecture to streamline the design, development, and deployment of EHR systems amidst system complexity prevalent in the healthcare domain. Through these studies, the section aims to advance the design and implementation of healthcare technologies by synthesizing existing research, identifying common patterns, and addressing critical challenges in the field.

III. APPROACH AND METHODOLOGY

Electronic Health Records (EHR) systems have been developed through fragmented software implementations, often ignoring crucial privacy and security aspects [28], although vital for modern healthcare infrastructure. Security and privacy measures, such as access control, data integrity, and audit controls followed by de-identification, emergency access, consent, secure transmission, authentication, and automatic logoff, are essential to maintain healthcare services' integrity and protect patient data [29], [30].

Despite the critical necessity, proactive strategies for mitigating risks in EHR systems are frequently developed and deployed without adherence to standardized reference architectures [22]. This emphasizes the necessity for reference architectures within the EHR domain, incorporating privacy and security considerations [31].

This paper aims to propose a Software Reference Architecture (SRA) for Electronic Health Records (EHRs) that integrates security and privacy requirements. By providing a standardized and well-defined architecture, this SRA can enhance the design and development of EHR systems. It helps healthcare organizations systematically incorporate security measures, such as encryption, access control, and privacy features, into their software architecture. This approach ensures compliance with regulations like GDPR and HIPAA,

reduces the risk of data breaches, and improves the protection of sensitive patient information.

We followed the approach presented in Figure 1 adopted from [12] to achieve the above objective. To define our methodology, we adhered to established guidelines outlined in the software engineering literature.

As presented in Figure 1, our approach consists of the following steps: i) Review of Concepts, ii) State-of-the-art Review, iii) Classifying the SRA, iv) Design of SRA, v) Evaluation of SRA, and finally, vi) Case study. We explain each step in the following subsections.

A. REVIEW OF CONCEPTS

In the first step, **Review of concepts**, we reviewed the concepts of reference architecture (RA) and software reference architecture (SRA) mainly, but not exclusively, from the software architecture books [32], [33], [34].

SRA emerged as abstractions of concrete software architectures within specific domains. Therefore, it provides a structured framework for designing and implementing software systems across various domains. It encompasses essential components and guidelines to facilitate development while maintaining system integrity, reliability, and scalability [35]. Valuable guidelines for designing reference architecture can be found in [32] and [36], particularly for systematically building software architecture for complex domains.

The study focuses on developing a security and privacy-aware SRA customized for EHR systems. Given the critical importance of security and privacy in modern software environments, particularly concerning healthcare data, we focus on integrating required measures within the SRA to mitigate risks and safeguard sensitive information [37].

Security and privacy-aware SRA for EHR should encapsulate design principles and security and privacy guidelines, including explicit guidelines described in [38]. These principles will govern the overall approach to system security, incorporating concepts such as defense-in-depth, least privilege, and secure by default. By adhering to these principles, the architecture ensures that security and privacy are incorporated in the software development lifecycle. Moreover, a Security and privacy-aware SRA should ensure compliance with industry regulations and privacy laws (e.g., GDPR [39], HIPAA [40]). Thus, it should integrate mechanisms for data anonymization, consent management, and audit trails to uphold legal requirements and safeguard user privacy rights [41].

Through adherence to security design principles, utilization of security patterns, robust data protection measures, and adherence to regulatory requirements, these architectures fortify software systems against security and privacy breaches. Meanwhile, continuous refinement and adaptation of reference architectures are imperative to address emerging security challenges in an evolving technological landscape.

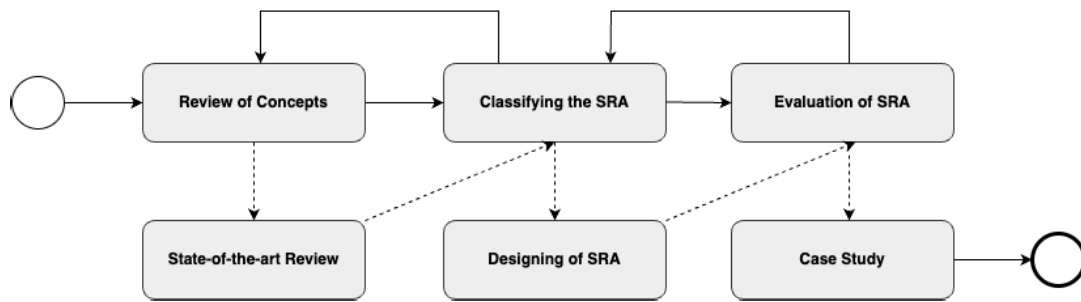


FIGURE 1. Methodology adopted to design a SRA for EHR systems [12].

B. STATE OF THE ART REVIEW

In the second phase, **State of the Art Review**, our objective is threefold: firstly, to conduct a literature review to identify the main stakeholders and the main components of EHR systems, and secondly, to determine the privacy and security requirements specific to EHR systems, and thirdly, to examine the current architectural solutions available for EHR systems. Regarding the primary stakeholder and the main component of EHR systems, we refer to the work presented in [2].

Regarding the privacy and security requirements, we refer to our previous study on privacy in electronic health records [10], in which we examined the current state of the art of privacy in electronic health records. In [10], we identified the main privacy challenges in EHR and the central privacy and security requirements identified by laws. We also searched for the published techniques providing privacy in the EHR systems and highlighted how well the existing techniques address the identified privacy and security requirements.

Regarding existing architectural solutions, we did not find any specific SRA tailored for Electronic EHRs with a focus on addressing security and privacy issues. However, we found the ISO 18308:2011 standard, which outlines the primary requirements for EHR system architecture to ensure alignment with healthcare needs, ethical standards, legal compliance, good clinical practices, and support for data analysis [42]. While ISO 18308:2011 offers valuable guidance for governing EHR systems, it does not comprehensively detail all requirements. Additionally, as previously mentioned, [36] provides several useful guidelines for systematically designing software for complex domains.

C. CLASSIFYING THE SRA

The third step, **Classifying the SRA**, aims to perform a preliminary analysis of the SRA needed for EHRs to evaluate the chances for the success of such a reference architecture. To do so, we refer to the work presented in [43] and [44]. In these works, the authors presented a framework for analyzing reference architectures (RA) in terms of congruence based on three dimensions, including context, goals, architecture design/specification, and the relationships

between them. As shown in Figure 2, there must be a strong connection between **context**, **goals**, and **design** to consider a reference architecture as congruent.

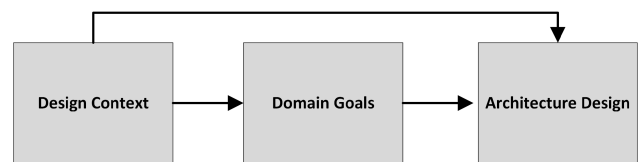


FIGURE 2. Relationship between context, goals, and design dimensions adapted from [44].

The RA is a classical facilitation architecture designed for multiple organizations. It is abstract, detailed, and semi-formal, describing system components and operations. In terms of **context**, which refers to the institutions where the architecture can be applied, RAs are classified into two categories: classical and preliminary. Classical architectures have extensive practical experience as they have been used over time. Preliminary architectures, on the other hand, are defined when there is not yet an extensive set of software systems in a given domain or type of system. They may exist solely as study experiments or even provide innovative architectural designs in relation to existing state-of-the-art systems [4]. The **goals**, on the other hand, concern the main purposes of the RA regarding its applicability within an organization and its primary objective.

The goal in software architecture and system design is inherently dynamic rather than static due to the continuous evolution of technology, business requirements, and user expectations. The dynamic nature of software systems necessitates a constant reassessment and adaptation of goals to accommodate changing environmental factors, such as emerging security threats, regulatory updates, technological advancements, and shifting market demands. Architectural goals must remain flexible and responsive to evolving challenges and opportunities, requiring architects to engage in ongoing evaluation and adjustment to ensure that the software architecture aligns effectively with the dynamic landscape of technology and business environments. This dynamic approach to goal fixation acknowledges the need for

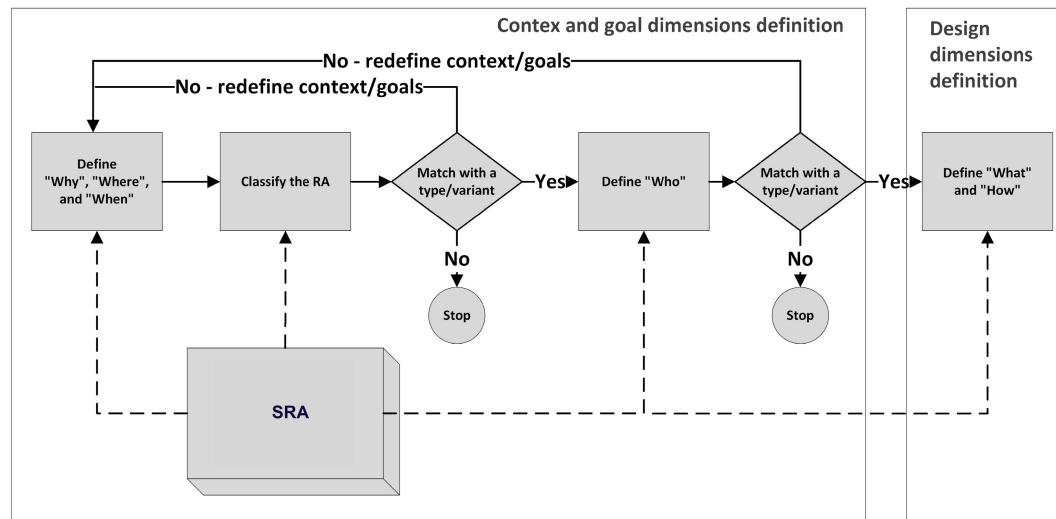


FIGURE 3. Framework for evaluation of congruent SRA adapted from [44].

agility and responsiveness in software architecture to meet the industry's and stakeholders' ever-changing demands.

Finally, the **design** dimension describes an RA from an operational perspective. In [43] and [44], an analysis framework including a set of sub-dimensions is identified within each of the aforementioned dimensions to distinguish aspects of the main dimensions [43]. The context sub-dimensions are guided by "Where?", "Who?" and "When?" questions. The goal sub-dimensions are guided by "Why?" questions, while the design sub-dimensions are defined by "How?" and "What?" questions. This analysis framework resulted in the definition of two principal groups of RAs, including standardization RAs and facilitation RAs, and five types of reference architectures that have a high probability of success. This analysis framework is depicted in Figure 3.

In this step, our objective is to conduct a similar analysis to characterize and determine the classification of the SRA we intend to develop for EHR systems. Based on the requirements of an SRA for EHR, which were previously identified, an SRA will be designed based on the works presented in [43] and [44]. Therefore, the SRA should take into consideration three dimensions according to its context (e.g., classical or preliminary), goals (e.g., facilitation or standardization), and design (e.g., algorithms or components). Thus, this study considers the SRA "congruent" if its goals are suitable to the context of the RA and its design reflects the goals and context [43].

To characterize the context, we must address three primary questions: where will the SRA be used? Who will define it? And when will it be defined? In this case, the SRA can be employed across **multiple organizations** within the healthcare domain [6]. In this study, the SRA is being defined within a **research center** by a team comprising two skilled and experienced software engineers and a healthcare professional. Furthermore, the SRA will serve as

a **preliminary architecture**, given the absence of software systems in the EHR domain addressing security and privacy concerns.

Regarding goals, we must address one principal question: why is the SRA defined? Here, the SRA aims to enhance privacy and security in EHRs, which should be considered as an essential aspect within an organization like healthcare, dealing with critical information such as diseases, patient health records, pre-existing illnesses, medical treatments, monitoring daily activities, and measuring personal data like blood pressure, heart rate, electrocardiogram (ECG), and breath analysis [6]. Hence, the SRA should **facilitate** the assurance of principal security and privacy requirements such as confidentiality, integrity, and availability of patient data while also meeting regulatory and ethical requirements.

To analyze the design dimension, we must address four primary questions: What is described in the design? How detailed is it described? How concrete is it described? And finally, how is it represented? In this study, we aim to define the **primary components** integrated into the SRA alongside the **principal algorithms and protocols** required to meet the aforementioned requirements. These aspects will be elaborated in **detail, presented in an abstract, formal, or semi-formal manner**. All these dimensions are summarized in Table 2.

Adopting and following the guidelines of [36] and [44], the SRA of this study is classified as Type 5 RA. Type 5 RAs are preliminary enabling architectures designed to be deployed across multiple organizations. Hence, they are designed to facilitate the design of system architectures that will become necessary in the future. Thus, these RAs are innovative and should define the essential components of a system.

It is worth noting that other features (e.g., Optimization, Automation, and Strong API Integration), in addition to design context and domain goals, could be used for

TABLE 2. Dimensions of SRA in this study.

	Dimension	Values
Context	C1: Where will it be used?	Multiple Organizations
	C2: Who defines it?	Research centers, by a team comprising two skilled and experienced software engineers and a healthcare professional
	C3: When is it defined?	Preliminary architecture
Goals	G1: Why is it defined?	Facilitation
Design	D1: What is described?	Primary Components, principal algorithms and protocols
	D2: How detailed is it described?	Detailed, semi-detailed
	D3: How concrete is it described?	Abstract
	D4: How is it represented?	Formal, semi-formal

classifying the RSA. However, utilizing the aforementioned classification model [43], [44] for EHR reference architectures in this study was driven by its accessibility, relevance to the healthcare domain, alignment with research objectives, and ease of communication. Despite the availability of more comprehensive models, the structured framework of the chosen model, tailored to healthcare settings, and its emphasis on enhancing privacy and security in EHR systems made it a practical choice for analyzing and designing SRAs in the healthcare sector. This clear framework aligns with the specific requirements of EHR systems and ensures an efficient and effective classification process within the healthcare domain.

D. DESIGNING SRA

The fourth step, **Designing SRA**, is focused on the design of SRA. After conducting the classification, we purposefully proceeded to the design phase of our SRA to enhance the privacy and security requirements in the EHRs. Furthermore, we considered the main components and connections between them discovered through the systematic mapping study [10]. Therefore, concepts from software architecture design methods were used to establish and document this SRA.

To design the SRA, we employ a well-defined notation such as UML, which can facilitate the understanding and implementation of the architecture.

It is worth noting that, according to the classification by [44], the architectures discussed earlier in the related work section are not SRAs and can be considered informal and fragmented architectures, as all studies use ill-defined graphical notes or natural languages. In addition, we did not find a study where an SRA was discussed semi-formally (well-defined notation like UML) or even formally. In their research, [45] discussed some benefits of following a formal architecture model. They noted that adopting and using a semi-formal architecture model ensures that the development team and requirements are organized at a high level before coding, making it easier for future team members to maintain the software application easily. Furthermore, [32], [46] highlight the benefits of having a formally designed

software development architecture that includes significant time and cost savings. However, although we intend to design an informal SRA, the previously discussed non-formal architectures are still helpful. We learn from the hands-on descriptions and use the information to build a concrete SRA that can be ideally reused. Therefore, we design and develop a formal SRA that is generic, systematic, and aligned with software architecture documentation guidelines.

E. EVALUATION OF SRA

After designing the SRA, it is necessary to verify whether the goals and design align within the given context. To achieve this, we apply a qualitative evaluation to determine the applicability of our architecture.

F. CASE STUDY

Finally, after designing the SRA, it was evaluated by performing a case study on Brazilian EHRs, which validates its adequacy.

IV. SOFTWARE REFERENCE ARCHITECTURE FOR EHR

This section presents a detailed description of the reference architecture proposed for an EHR system to enhance privacy and security within these systems.

A. LAYERED ARCHITECTURE

Several studies [47], [48], [49] have proposed generic architectures for EHRs. According to the literatures [12], [30], and [50], an SRA layered architecture for EHRs should include the following principal components: Data Management Layer, Healthcare Logic Layer, Presentation Layer, Security Requirement Layer, and Privacy Requirement Layer. Figure 4 presents a general view of such a layered architecture.

The presentation layer, healthcare logic layer, and data management layer are essential for designing and developing an EHR system's core functionalities. On the other hand, the security and privacy requirements layers are transversal to the other three layers and aim to enhance security and privacy in EHR systems. The following sub-section will detail the function of each layer of this layered architecture through a

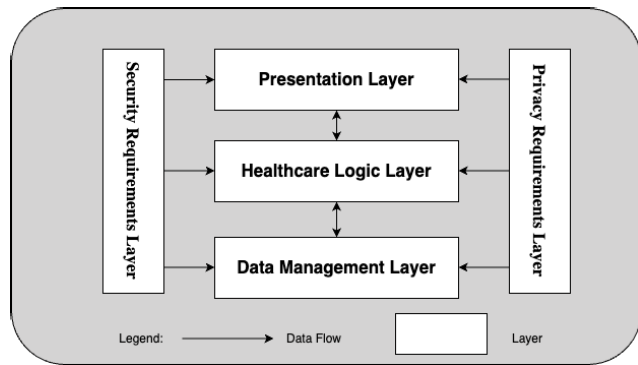


FIGURE 4. SRA layered architecture for EHR systems.

feature diagram, layer view, context view, and decomposition view.

B. SRA FEATURE DIAGRAM

Figure 5 illustrates the SRA feature diagram [51], showcasing the typical domain features of an EHR system. These features are organized according to the five principal layers outlined in the layered architecture. The derivation of these features originated from an extensive domain analysis process, wherein we thoroughly examined key publications to identify standard features.

As shown, the top-level features (i.e., Presentation, Healthcare Logic, Data management, Security, and Privacy) correspond to the layers defined within the SRA Layered Architecture (see Figure 4).

1) PRESENTATION

The presentation contains the interface visualization feature. Interface Visualization is required when the user needs to access the system, including the Patient Interface and Management Interface.

- 1) **Patient Interface** enables users to access the system through a graphical interface. The initial and visual screens are accessible to the users that make up these systems.
- 2) **Management Interface** is dedicated to reporting and system analysis, which is essential for any computer system. Reports serve to efficiently outline the results of some activity carried out, focusing on critical points relevant to the context.

2) HEALTHCARE LOGIC

The healthcare logic feature is responsible for the fundamental modules the EHRs must have.

EHR is the feature responsible for managing the patient's electronic records. Thus, it is part of the system with the interfaces responsible for accessing and handling data about the patients. EHR includes four principal features: Healthcare Professional View, Clinical Assessment View, Patient Profile Management, and Account Management.

- 1) **Healthcare Professional View** provides healthcare professionals access to vital patient medical records, ensuring they have the necessary information to deliver high-quality (efficient and effective) healthcare. Moreover, healthcare providers can insert clinical notes documenting each encounter with the patient, including symptoms, diagnoses, treatment plans, and outcomes. Furthermore, it should provide healthcare providers with tools for prescribing medications, managing prescriptions, and checking for potential drug interactions or allergies. It may also include clinical decision support tools to assist healthcare providers in making informed decisions about patient care and reporting and analytics tools for generating reports and analyzing data to monitor population health trends and improve healthcare quality and efficiency on a global scale.
- 2) **Clinical Assessment View** is responsible for storing and presenting the results of clinical assessments, including laboratory data (e.g., blood tests and urine tests), radiology reports, and diagnostic imaging (e.g., X-rays and MRIs). These data must be integrated into the patient's records.
- 3) **Patient Profile Management** is where the healthcare system administrator manages patients' profiles. Patient profile includes patient demographics, including basic information about the patient such as name, age, gender, contact details, insurance information, and medical history, including past illnesses, surgeries, allergies, medications, immunizations, and family medical history.
- 4) **Account Management** is where users can access their account details. This module provides information regarding the user's account, such as their username and password, and personal information, such as age, education level, and family name.

3) DATA MANAGEMENT

Database management is responsible for internal data storage and processing. Data Management within EHR systems should incorporate key features such as interoperability, scalability, data retention and archiving, and backup and disaster recovery, collectively strengthening data accessibility, reliability, and security in healthcare operations.

- 1) **Interoperability** ensures seamless data exchange between systems for comprehensive patient care.
- 2) **Scalability** enables EHR systems to adapt to growing demands.
- 3) **Data retention and archiving** ensure compliance and efficient data storage.
- 4) **Backup and disaster recovery** safeguard against data loss and ensure service continuity in adverse scenarios.

4) SECURITY

In the context of Electronic Health Records (EHR), security requirements such as accountability and audit control,

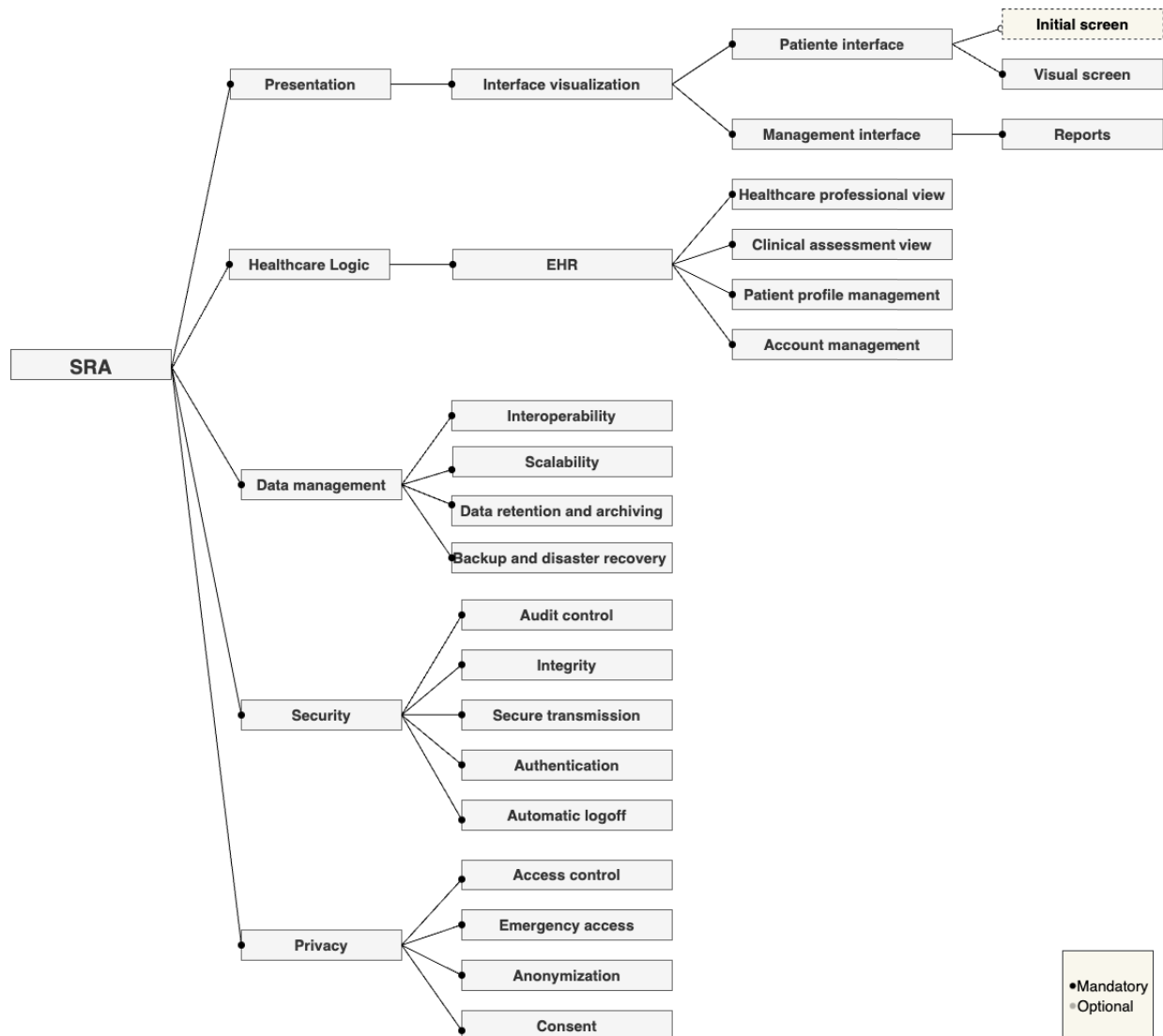


FIGURE 5. SRA feature diagram of the SRA.

integrity, secure transmission, authentication, and automatic logoff play critical roles in safeguarding patient data and ensuring the confidentiality, integrity, and availability of healthcare information.

- 1) **Accountability and Audit Control** involves monitoring and recording access to EHR systems, tracking user activities, and maintaining audit logs to detect unauthorized or suspicious behavior. By implementing audit controls, healthcare organizations can track data access, identify security incidents, and comply with regulatory requirements, enhancing transparency and accountability in EHR usage. Studies by Ibrahim and Singhal [52] and Sharma and Balamurugan [53] highlight the importance of audit systems in tracking information flow, maintaining data integrity, and detecting unauthorized access within EHR systems. By leveraging cryptography and blockchain

technology, these studies emphasize the role of audit controls in enhancing transparency, accountability, and compliance with privacy regulations, ultimately contributing to a more secure and privacy-aware EHR environment [54]. In addition, integrating accountability and audit mechanisms in EHR systems plays a pivotal role in ensuring patient data security, privacy, and regulatory compliance. Accountability establishes clear responsibilities and processes for data management, while audits provide systematic reviews to validate security measures and detect unauthorized activities. By combining these elements, EHR systems can enhance transparency, fortify security controls, and demonstrate adherence to privacy regulations, fostering a culture of responsibility, trust, and regulatory compliance in managing sensitive healthcare information [55].

- 2) **Data Integrity** is a security property that protects data from unauthorized alteration or destruction. Its purpose is to establish and implement policies and procedures to safeguard Protected Health Information (PHI) from being accidentally or intentionally compromised by employees or due to electronic media errors or failures. Integrity can be achieved through various techniques, such as encryption, access control, redundancy, and backup. Technologies like blockchain can also help to achieve integrity. The study presented in [56] suggests the use of blockchain records transactions in a tamper-proof and chronological manner, ensuring the integrity and immutability of EHR data. It prevents unauthorized modifications to patient records and enhances data reliability and trustworthiness.
- 3) **Secure Transmission** involves encrypting data during its transfer between systems, ensuring that sensitive information shared over networks remains confidential and protected from interception or unauthorized access. By using encryption protocols such as SSL/TLS, healthcare organizations can establish secure communication channels for transmitting EHR data securely, mitigating the risk of data breaches or eavesdropping. For instance, Sharma and Balamurugan [53] propose a blockchain-based framework for secure EHR storage and support, emphasizing the use of encryption and decentralization to enhance data security during transmission. Additionally, Edemacu et al. [24] discuss access control methods, including encryption-based techniques, to ensure secure data transmission in EHR environments. These studies underscore the importance of implementing secure communication protocols, encryption technologies, and access control mechanisms to safeguard patient information, prevent unauthorized access, and maintain privacy compliance in EHRs.
- 4) **Authentication** is employed to ensure secure access control. Studies emphasize the importance of authentication mechanisms for secure access to EHR systems. For instance, Farhadi et al. [57] provide insights into access control methods, including authentication-based approaches, to enhance security in EHR environments. Meanwhile, Mamun and Rana [25] discuss authentication, encryption, and access control techniques to protect patients and offer a robust authentication model using multi-channel communication for healthcare systems to enhance privacy and security. These studies underscore the role of strong authentication protocols, such as biometric and multi-factor authentication (MFA), in verifying user identities, preventing unauthorized access, and maintaining EHR data confidentiality.
- 5) **Automatic Logoff** features automatically terminate user sessions after inactivity, reducing the risk of unauthorized access to EHR systems when users

leave their devices unattended. By enforcing automatic logoff policies, healthcare organizations can prevent unauthorized data access, enhance user privacy, and maintain data security compliance, promoting secure EHR usage and patient. Thus, Farhadi et al. [57] emphasize the significance of automatic logoff features to prevent unauthorized access to user data and protect the privacy of information stored in EHRs, shed light on the critical role of automatic logoff functionalities in mitigating privacy risks and ensuring secure access control in EHR environments.

Overall, security requirements are essential components of a comprehensive security framework for EHR systems, helping healthcare organizations mitigate risks, protect patient information, and uphold the confidentiality and integrity of electronic health records in today's digital healthcare landscape.

5) PRIVACY

Privacy requirements such as access control, emergency access, anonymization, and consent are crucial for protecting patient confidentiality, ensuring data privacy, and upholding ethical standards in healthcare information management:

- 1) **Access Control** mechanisms regulate and restrict user permissions within EHR systems, allowing only authorized individuals to view or modify patient records. Therefore, access control mechanisms play a crucial role in ensuring data security and privacy within EHR systems, emphasizing the importance of access control in managing data access and preserving patient privacy. Studies by Xu et al. [58] present a new approach to ensure user privacy by preserving the revocable ciphertext policy attribute-based encryption (PR-CP-ABE) scheme, enabling users to revoke privileges and protect privacy immediately. In addition, Essa et al. [59] proposes a new approach to data security in IFDDS healthcare environments using encryption algorithms distributed between different platforms in the cloud. The main objective is to protect sensitive data stored with the least possible impact on latency and performance. Besides that, other studies suggest that by implementing robust access control measures, healthcare organizations can enforce data privacy regulations, prevent unauthorized disclosures, and maintain the confidentiality of EHR [48], [60].
- 2) **Emergency Access** provisions enable designated personnel to access critical patient information in urgent situations, such as medical emergencies or life-threatening scenarios. By establishing emergency access protocols, healthcare providers can ensure timely access to vital healthcare data, facilitate prompt decision-making, and support patient care delivery while maintaining data security and confidentiality. In this context, EHR platforms should incorporate mechanisms for healthcare professionals to retrieve

user data swiftly during emergencies, particularly when manual authorization by the user is unattainable. This approach, commonly referred to as Break-the-Glass (BTG), as discussed by Jayabalan and O'Daniel [61], underscores the importance of balancing privacy concerns with the imperative of immediate data access in critical situations. Furthermore, Eom and Lee [62] propose a patient-controlled attribute-based encryption (PC-ABE) framework, empowering users to manage access to their health information. This method grants users comprehensive control over their data and the ability to authorize access. In emergency scenarios where the individual is incapacitated and unable to access their personal health information (PHI), an access key is generated to facilitate medical teams' access to their private data. Importantly, this access key is tailored to the specific patient and is time-limited to prevent unauthorized data breaches post-emergency care.

- 3) **Anonymization** refers to the process of removing, modifying, or reducing personal data (i.e., personally identifiable information (PII) like name and Quasi-identifiers like age, sex, address) in a way that individuals cannot be, directly or indirectly, identified. There are several techniques to achieve this, including removal or encryption of personally identifiable information (PII) and generalization, perturbation, suppression, and anatomization of quasi-identifiers [63], [64]. Examples of effective privacy models for anonymization include k-anonymity [65], ensuring each record is indistinguishable from at least k-1 others; l-diversity [66], which extends k-anonymity by diversifying sensitive attributes; and t-closeness [67], which maintains the distribution of sensitive attributes within each group. These techniques help healthcare organizations de-identify patient records, reduce the risk of re-identification, and securely use data for research or analytics without compromising individual privacy.
- 4) **Consent** management processes involve obtaining patient consent for data collection, use, and disclosure within EHR systems, ensuring transparency, autonomy, and respect for patient privacy preferences. By implementing informed consent practices, healthcare providers can empower patients to make informed decisions about their health information, establish trust in data-sharing practices, and comply with legal and ethical requirements for patient privacy protection, fostering patient-provider relationships based on mutual respect and confidentiality. Therefore, obtaining explicit consent from individuals regarding using their health data is fundamental to privacy protection. Studies by Zhang et al. [68] and Mamun and Rana [25] propose frameworks emphasizing the importance of consent mechanisms in electronic health record systems. Zhang et al. [68]

present a framework that utilizes conditional proxy re-encryption algorithms to enable data exchange based on user consent, ensuring that data requesters seek user permission before accessing their information. Mamun and Rana [25] introduce a hybrid model for access control in Personally Controlled Electronic Health Records (PCEHR) that integrates cryptographic techniques with multichannel authentication and context restrictions to enhance security and privacy. These studies underscore the significance of incorporating consent-based access control mechanisms to safeguard patient privacy and ensure data confidentiality in electronic health record environments.

By addressing these privacy requirements in EHR systems, healthcare organizations can enhance data privacy, promote patient trust, and uphold ethical standards in healthcare information management, ultimately supporting patient-centered care, data security, and regulatory compliance in the digital healthcare environment.

C. ARCHITECTURAL VIEWS

Although the EHR's principal purpose is to assist in the current daily procedures, it should also be adaptable to simplify different long-term visions. An architectural view organizes and structures the proposed points of view [69]. Thus, a widely used SRA framework for documenting architectural views is the "Views and Beyond" approach proposed by [34]. They differentiate between three different types of views and further divide them into 17 subcategories. The SRA must handle all the resources considered helpful from the SRAs discussed earlier. First, a **context view** is shown to define the scope of the system within the external domain [12]. Second, a **decomposition view** is provided to define the composition of the system's key features. The Unified Modeling Language (UML), a semi-formal graphical language, describes the system [70]. Finally, a **layer view** helps to visualize the architecture by grouping the UML diagrams and models into layers [71].

1) CONTEXT VIEW

A context view is usually represented with a context diagram and shows the system's connection with entities outside the scope of the system. It presents information about what is and is not contained in the system [12]. Figure 6 illustrates the context view of the SRA proposed in this study for security and privacy-aware EHRs. External entities and their interactions with the SRA are identified based on the stakeholders and their concerns outlined in Table 3.

As depicted in the figure, six external entities (e.g., Healthcare manager) crucial for EHR functionality have been identified, along with several optional entities such as other EHRs, which may not be present in simpler EHR architectures. In addition, some (sub)domains may require specific entities not shown in the reference context diagram. Many entities have two ways of communicating with the

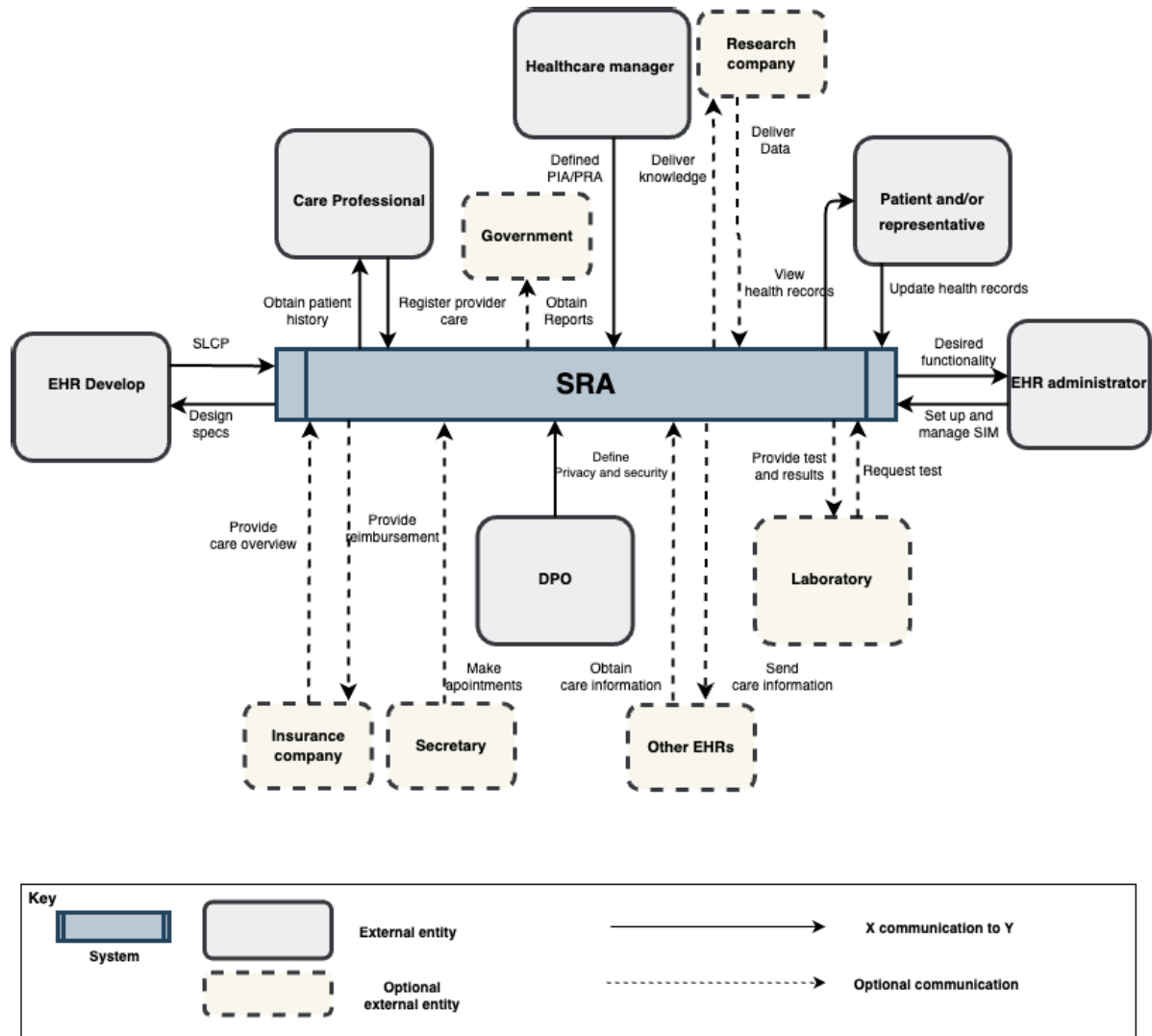


FIGURE 6. The context view of the SRA.

EHR, which means that the EHR communicates with the entity and vice versa. External entities with unidirectional communication with the EHR are rare. For example, a government organization might receive reports from EHR, but this organization needs authorization to access EHR data. We just described a type of communication by interaction due to space limitations. In practice, there are many more possibilities.

According to the Project Management Institute, a stakeholder is “an individual, group, or organization who can affect, be affected by or perceive itself to be affected by a decision, activity, or outcome of a project” [72].

The six principal stakeholders of EHR systems and their primary concerns for health development are presented in Table 3 [12]. While some stakeholders are generic to EHRs, such as the patient, others are more specific domains, such as the laboratory.

In healthcare data management, safeguarding EHRs against potential threats and adversaries is paramount to ensure data privacy, security, and regulatory compliance. Adversary and threat models, along with Privacy Impact Assessments (PIA) and Privacy Risk Assessments (PRA), play a crucial role in fortifying EHR systems within a comprehensive framework, particularly in alignment with regulations like the General Data Protection Regulation (GDPR). Therefore, the mechanism for a PIA was introduced with the GDPR (Art. 35) [73]. This aims at the controller’s obligation to carry out an impact assessment and document it before processing the information [19]. A PIA is an impact assessment conducted by an organization with access to confidential and private data about individuals stored or handled without its system [74]. Thus, the organization must review its processes to determine how they affect or may compromise the privacy of the users whose data it

maintains, collects, or processes. Roger Clark defines PIA as “a systematic process for evaluating the potential effects on privacy of a project, initiative or proposed system or scheme” [75].

A PIA aims to identify and record the components essential in any proposed system containing considerable personal information and to demonstrate how the privacy risks associated with that system can be addressed. A PIA sometimes goes beyond an assessment of a “system” and considers critical effects on people who are affected in some way. Hence, the success of projects depends on meeting legislative guidelines or policies about privacy requirements and community expectations of privacy. Thus, if privacy issues are not adequately defined, this can affect community trust in an entity and challenge the project’s success [19].

A PIA is appropriate for addressing privacy risks within a healthcare provider’s risk management approach. Thus, while the holding out of a PIA is not an obligatory legal requirement, the commissioner will often ask whether a PIA has been carried out and will invariably require one when public sector organizations seek to obtain a public interest determination, aim to establish a contract use of information, or request certification.

Meanwhile, the Privacy Risk Assessment (PRA) is responsible for assessing an organization’s level of privacy risk. This module (i) considers the current cybersecurity status acquired by the Cybersecurity Risk Assessment module and (ii) performs the analysis of data processing operations to uncover potential privacy risks in alignment with GDPR objectives and protect sensitive user data. More specifically, it performs privacy risk analysis based on cybersecurity evidence from deployed infrastructure sensors and the organization’s documented data processing actions. For this, the PRA considers the interrelationships between Information and Communication Technology (ICT) infrastructure assets that support data processing activities, data sources, data subjects, and personally identifiable information (PII) and infers the privacy risks that an organization may face due to vulnerabilities and threats targeting it. The privacy assessment process results in a list of possible mitigation measures that security administrators can apply. These action measures can only help cybersecurity decision-makers (e.g., information security officers) define mitigation strategies based on computed privacy scores [76].

Therefore, incorporating PIA and PRA into a framework proposal for protecting EHRs involves identifying potential adversaries such as insider threats, external hackers, and third parties and considering threat scenarios like unauthorized access, data breaches, and data tampering. Mitigation strategies, including access control, encryption, audit trails, user training, and incident response planning, can be implemented to address these threats. In addition, by integrating PIA and PRA, healthcare organizations can proactively manage privacy risks, implement security controls, and ensure continuous monitoring to safeguard EHRs

and maintain patient data’s confidentiality, integrity, and availability.

2) DECOMPOSITION VIEW

The decomposition view shows how a system can be decomposed into multiple (sub)modules and how is the relationship among them (e.g., parent-child). This view often is the foundation for SRA design, development, and system documentation [77]. The decomposition view allows checking for the existence of the required modules for all stakeholders.

The SRA decomposition view in this study, as shown in Figure 7, consists of five modules with twenty-four sub-modules. The first module is the presentation module, containing sub-modules related to how the user interacts with the EHR system. The second module, healthcare, is related to the fundamental modules that the EHR system must have as status and referrals of patients and is input for the electronic health record. The third module, data management, concerns the interaction and construction of the internal database. The fourth and fifth modules, privacy and security, are the main ones and are the main focus of this study. These modules must enhance the privacy and security of data stored and exchanged between EHR systems. The security module includes the sub-modules of integrity, secure transmission, authentication, automatic logoff, and audit control, and the privacy module includes the sub-modules of access control, consent, emergency access, and anonymization mechanisms must ensure the security and privacy of the EHR and its data.

3) LAYERED VIEW

The layered view reflects the sequence of software modules in distinct layers based on a one-way “allowed to use” association between layers [34]. We determined to base our layered view on the pattern of enterprise software systems due to their flexibility (see Figure 8). At the top UML reference, the layered view comprises a presentation layer with a user interface (UI). The presentation layer depends on the healthcare logic layer, determining how the EHR is accessed, how the data is accessed, and how healthcare professionals using the EHR are consulted. In addition, the data management layer is responsible for how the data is created, stored, and processed. Thus, the presentation layer concerns how the user interacts with the system. Hence, the data management layer contains submodules for simplifying access to data. The vertical layer connected to all three horizontal layers was added to provide privacy and security requirements in EHR. This security layer contains the following modules: Integrity, Secure Transmission, Authentication, Automatic Logoff, and Audit Control mechanisms for security and protection at all system layers. Whereas the privacy layer contains the modules: Access Control, Emergency Access, Consent, and Anonymization. Hence, these requirements provide privacy for EHR users [10].

TABLE 3. The identified stakeholders and their concerns.

Role	Concerns
Care Professional	provides medical care and services to patients and is concerned about the EHR system being easy to use, enabling quick entry, retrieval, and sharing of data.
Healthcare Manager	is responsible for managing the operations and administrations of healthcare centers and is concerned about the EHR system being able to provide summaries and generate reports (e.g., about healthcare services, resources, and cost), helping to ensure that healthcare facilities provide high-quality care to patients while also managing resources effectively.
EHR Developer	is responsible for design, implementation, testing, deployment of EHR system and is concerned about meeting both functional and non-functional requirements of the system including availability, performance, interoperability, security, and privacy.
Patient and/or representative	receives medical care and services and is concerned about the quality of the services (e.g., access to the right information at the right time and smooth data transmission) and data protection in the EHR system.
EHR Administrator	the technical aspects of the EHR system, ensuring its successful implementation, ongoing maintenance, and continuous improvement. He/she is concerned about ease of maintenance and thorough documentation to streamline operations and facilitate future updates effectively.
Data Protection Officer (DPO)	is a specialist responsible for ensuring compliance with relevant data protection rules and laws such as Privacy Impact Assessment and Privacy Risk Assessment. He/she is concerned about the integration of security and privacy features into the EHR system.

V. CASE STUDY

This section presents the SRA evaluation. For this evaluation, a case study was carried out to seek evidence to answer the research questions that an SRA for EHR applications is an adequate approach to address the security and privacy challenges encountered in developing this type of software. Thus, the case study research process presented by [78] and [79] was followed. The results of conducting this process are presented in the following subsections.

A. CASE STUDY OBJECTIVE

The main objective of this case study is to validate the adequacy of the SRA in supporting the architectural design for the development of healthcare systems, emphasizing EHRs and enabling these systems to become more secure and have privacy requirements already at the time of their development.

B. CASE STUDY DESIGN

We analyze the EHR in a primary care system (i.e., Sistema de Atenção Primária (e-SUS APS)) in Brazil to detail how these systems deal with policies and laws regarding preserving users' privacy. This analysis was compared with the SRA design for comparison purposes. The E-SUS APS is a system developed by the government of Brazil. It is designed to provide primary care units in all states and cities with a comprehensive information management system. This system stores and handles patient data from Basic Health Units (i.e., Unidades Básicas de Saúde (UBS)). These UBS facilities serve as Brazil's primary entry point to the unified healthcare system (i.e., Sistema Único de Saúde - (SUS)). The UBS is the preferential gateway to a unified health system SUS. These UBS care for up to 80% of the population's health

problems without needing referral to other services, such as emergencies and hospitals [80], keeping patient records within a single system. Thus, UBS aims to serve patients who need medical care more quickly before being sent to hospitals, so it is considered a primary health system and vitally important for Brazilians [81].

The e-SUS APS is a strategy by the Department of Family Health (i.e., Departamento de Saúde da Família (DESF)) to restructure Primary Health Care (PHC) information at the national level. This action aligns with the more general proposal for restructuring the Health Information Systems (HIS) of the Ministry of Health (MH), understanding that the qualification of information management is essential to increase the quality of care for the population. The e-SUS APS strategy refers to the qualified computerization process of the SUS in search of an electronic SUS. It aims to implement a new information management model that supports municipalities and health services in the effective management of the PHC and the qualification of the users' care. Therefore, the e-SUS APS strategy aims to:

- Identify and Individualize the Registry: the individualized record of health information and identified, through the Individual Registration (Cadastro de pessoa física (CPF)) or National Health Card (NHC), to monitor the care provided to the citizen;
- Integrate information through the National Health Data Network (i.e., Rede Nacional de Dados em Saúde (RNDS)) integrate the RNDS by sending health data based on standardized information models;
- Reduces rework in data collection: reduces the need to record similar information on more than one instrument (cards/systems) at the same time;

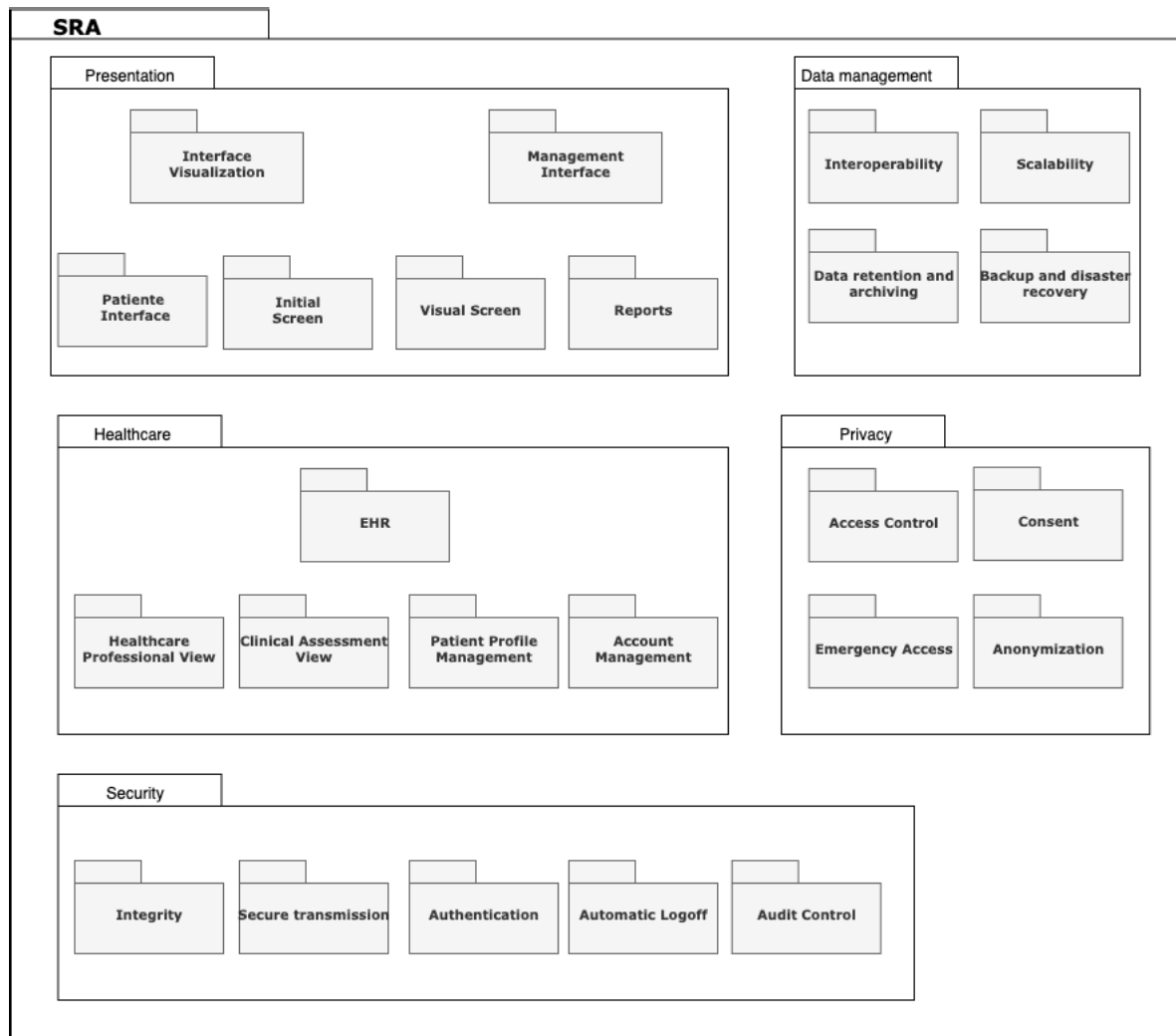


FIGURE 7. The decomposition view of the SRA.

- Computerize the units: development of technological solutions that include PHC work processes, with recommendations for good practices and incentives for the computerization of health services through the APS Program;
- Qualify health data: promote the qualification of health data entry through standardizing terminologies and adopting clinical record methodologies;
- Care management: introduction of new technologies to optimize the work of professionals in care management;
- Care coordination: optimizing information in health management and care from the perspective of integrating health services.

E-SUS APS system, consisting of two software and two applications for data collection:

- Simplified Data Collection System (i.e., Coleta de Dados Simplificada (CDS)), transition/contingency system, which supports the data collection process through forms and typing system;

- Electronic Citizen Registration System (i.e., Prontuário Eletrônico do Cidadão (PEC)), an electronic health record system (EHR), aims to support the UBS computerization process.

Moreover, the system that has been analyzed is e-SUS PEC, as this software is responsible for patient records.

C. DEPLOYMENT VIEW

To better understand how the system was implemented and how its components are represented within the e-SUS PEC, we carried out a deployment view (see Figure 9). Hence, in the image, we highlight the main modules that are part of the e-SUS PEC [82]. Thus, the description of the modules that make up the system is discussed below.

In Brazil, several difficulties are related to computerizing primary healthcare systems managed by municipal governments. For this reason, CDS is a way of registering patients when the system does not have an internet connection. Therefore, Simplified Data Collection is one of

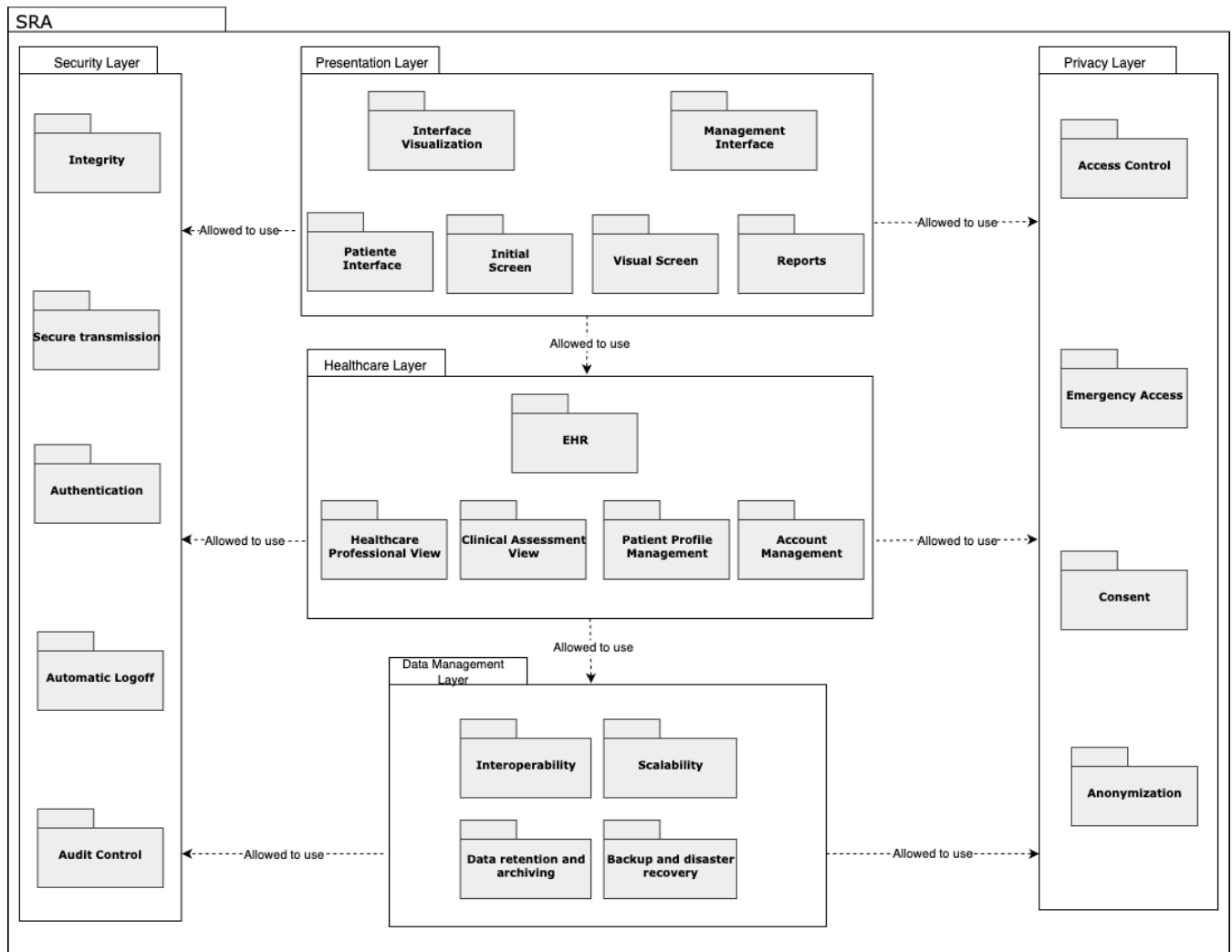


FIGURE 8. The layered view of the SRA.

the components of the e-SUS PEC, used mainly in health services that do not have a computerized system for routine use at work. Interface visualization is responsible for users' login page using the E-SUS PEC. Besides that, it also provides access to the system's internal configuration and parameterization modules. The reports module allows staff in the UBS and managers to visualize the health actions carried out in the territory in a summarized and systematized. As a result, several reports are divided into consolidated, production, and operational. The scheduling module is used to organize the schedule of professionals at UBS. It is the primary tool used by staff at receptions at UBS. This module is available in the PEC and was designed considering technological advances and the increasing constant access of the population to smartphone devices, thus having access to mobile applications. The citizen module is where users with access to patient records can access, add, and change information. In addition, to store the information, the E-SUS PEC uses a database for local storage and transmits it to

the national SISAB through scheduling. Thus, the SISAB is the current national information system for processing and disseminating data and informing action aims to build knowledge and make decisions [84].

D. COLLECTING EVIDENCE

The analysis was conducted on a Server Dell XPS 8950 with 32GB 2400MHz DDR5 RAM and 2.80GHz Intel Core i7-12700 (12-core, cache 25MB with 4 cores and 8 threads (2 threads per core) processor, and SSD de 512GB PCIe NVMe M.2. The development of e-SUS PEC is cross-platform. Hence, it can be installed on different operating systems (OS). Thus, we prefer to install the system over Ubuntu Linux. The e-SUS PEC System supports some types of databases. By default, the system with PEC, from version 2.0, comes with PostgreSQL as an internal database. As a result, this database is configured by default at system installation. It can be used in UBS with a local server or

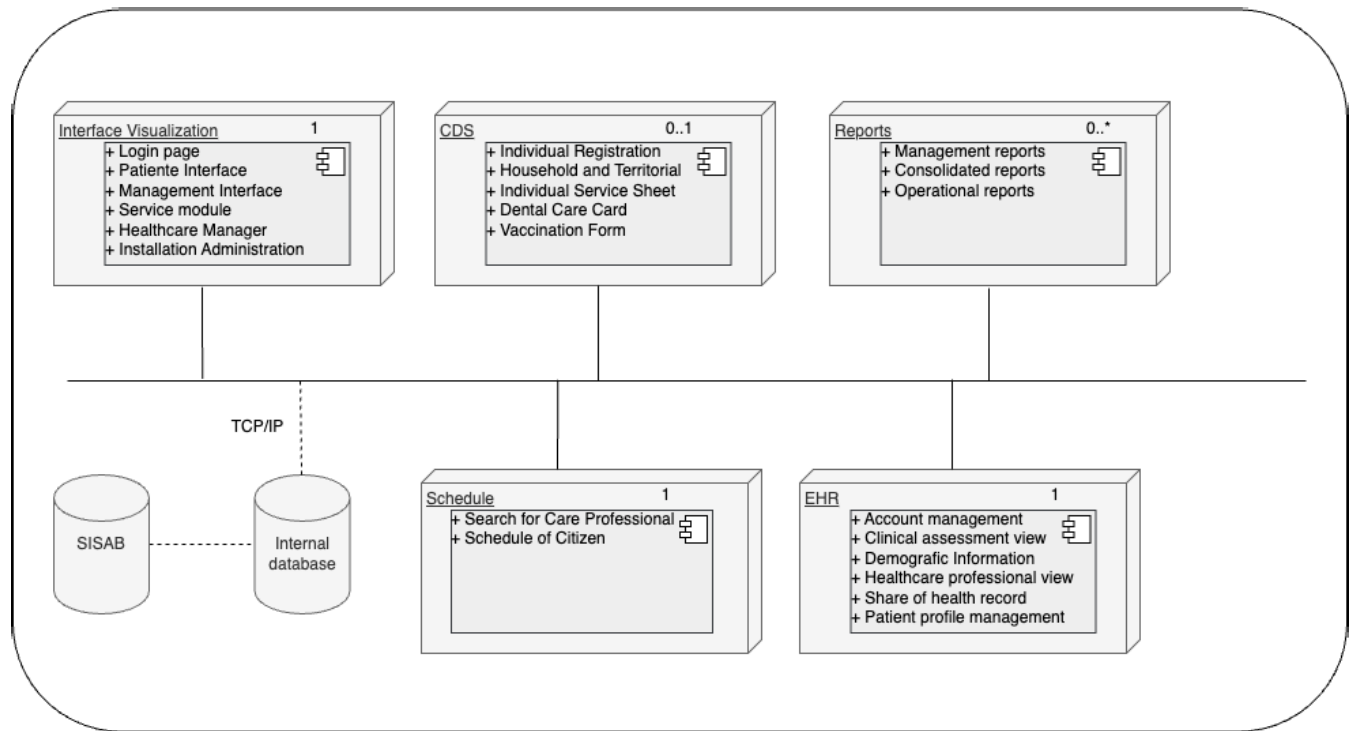


FIGURE 9. Deployment view for the E-SUS PEC [83].

for centralized installations. Therefore, our objective was to evaluate the EHR, not the system's performance. Thus, our installation was based on a typical installation for up to 40 simultaneous users [81].

E. REQUIREMENTS TRACEABILITY MATRIX (RTM)

RTM is the process of tracing the applying requirements to various software development artifacts [85]. Besides that, requirements traceability is a vital element of requirements engineering (RE) as it can provide visibility into the required factors of the software and system development procedure, contributing to a better understanding of the software system underneath development [86]. Moreover, rapid changes or additions to the requirements in the application development process exist [87]. This happens because the customer is part of the development team providing input and adjustments. Thus, very intense communication processes and the simplification of documentation often make it hard for developers to keep track of the progress of implementing the overall application requirements. Therefore, requirements tracing is necessary to ensure that application development is running correctly and keeping up with requirements privacy and security necessary [88]. Hence, automated tracking with good efficiency scalability needs to be implemented to form the correct track links. Thus, requirements traceability is performed based on the formulation of the structure of written language. Also, manually applying requirements tracing requires effort and time, especially with high complexity [89].

RTM can be considered the spine of any project and helps ensure accurate delivery to meet users' expectations. Therefore, RTM has the ability to verify that technical requirements have been met by functional ones that will, in turn, satisfy system requirement needs. So there are several requirements. However, our primary focus is privacy and security requirements. Thus, privacy and security requirements are aspects of desired end products, such as the degree to which a system and its data are protected from threats.

We perform the RTM on the e-SUS PEC to verify that the system follows the security and privacy requirements. The columns of the RTM are defined in Table 5. In addition, as can be seen, Table 4 shows us the requirements that were met and not met. In the next section, we are discussing our analysis.

VI. DISCUSSION OF THE RESULTS

To the best of our knowledge, this is the first SRA that aims to enhance privacy and security issues in EHRs design using community software architecture approaches. Well-established architectural models and approaches were followed to design our SRA to answer these two research questions, as follows:

Question 1: "How to constitute a viable Software Reference Architecture (SRA) for Electronic Health Records (EHRs) that systematically integrates privacy and security considerations?"

An SRA for EHR systems is crucial for ensuring security, privacy, and efficient data management within healthcare

TABLE 4. Privacy and security requirements traceability matrix (e-SUS PEC).

ID	Ass. ID	Requirement	Category	Software Module(s)	Result	Additional Comments
1	1.1	Access Control	Privacy	e-SUS APS Management/profile	Met	The access control model used by the e-SUS PEC system is based on roles, depending on their professional profile, such as doctors or nurses having access to all patient information.
2	2.1	Emergency Access	Privacy	Not Assigned	Not Met	none
3	3.1	Anonymization	Privacy	Citizen\Citizen view	Not Met	The PHI does not de-identify all users can see private information such as (CPF, Race, Telephone number, PIS/PASEP number, and blood type)
3	3.2	Anonymization	Privacy	Citizen\Citizen View\Cover Page	Not Met	To access personal information, insert a justification for viewing the medical record. However, the information PHI sticks to can be seen for another user.
4	4.1	Audit Control	Security	Internal database	Met	If the professional wishes to view the medical record through the Citizen module, it is mandatory to register a justification for accessing this clinical information outside the time of care or in the absence of the citizen at the UBS. This justification is recorded in the database for later use in the case of an audit in relation to the secrecy of the citizen's sensitive clinical data.
5	5.1	Integrity	Security/Privacy	Not Assigned	Not Met	The integrity of the database is the responsibility of the municipal department responsible for installing the system. To ensure data integrity and the correct functioning of the system, information must be entered or imported through e-SUS APS PEC. Carrying out a data backup prevents the total loss of stored information in the event of any eventuality and must be carried out periodically.
5	5.2	Integrity	Security/Privacy	Not Assigned	Not Met	Furthermore, the data is not natively encrypted by the system. No encryption mechanisms were identified, which do not guarantee the complete integrity of user information in the system.
5	5.3	Integrity	Security/Privacy	Not Assigned	Not Met	The data stored in the e-SUS PEC are not encrypted by default. Thus, this task is the responsibility of the system administrator responsible for installing and maintaining the system.
6	6.1	Secure Transmission	Security/Privacy	e-SUS APS Management /Municipal Management	Met	Data transmission to the national health data network is encrypted through digital certification A1 that can be configured using a key provided by the government (DATASUS).
7	7.1	Authentication	Security	Login page	Met	The method is based on user and password. Besides being the default for login to the e-SUS PEC system. However, the login page has no encryption (http://localhost:8080/)
7	7.2	Authentication	Security	Login page	Met	The authentication process can also hereby gov.br in the e-SUS PEC.
8	8.1	Consent	Privacy	Citizen	Met	The e-SUS APS System, to guarantee the citizen's consent, is opt-out, that is, every citizen will have their data shared within the primary care service of the municipality, in line with the recommended care model. However, if the citizen chooses not to share their service data, they need to request the blocking of sharing by updating their registration (in the Citizen module).
8	8.2	Consent	Privacy	Citizen	Met	Patients can choose how their clinical data is made available to the health network. By default, their data is visible to all emergency care units in the same facility, as it optimizes the retrieval of relevant clinical information for care. If the citizen disagrees, check the option "Disable sharing of medical records for this citizen" .
9	9.1	Automatic Logoff	Security	Installer\Installation settings\security	Met	Period for resetting the password of professionals accessing the PEC.
9	9.2	Automatic Logoff	Security	Installer\Installation settings\security	Met	Timeout for closing the session due to system inactivity.
9	9.3	Automatic Logoff	Security	Installer\Installation settings\security	Met	The maximum number of consecutive login attempts with invalid authentication.
9	9.4	Automatic Logoff	Security	Installer\Installation settings\security	Met	Manual request to reset passwords for all system users.

organizations. Therefore, a feasible SRA for EHRs should consider the following key aspects:

- The SRA should incorporate robust security measures to protect sensitive patient information. These measures should include encryption, access controls, audit trails, authentication mechanisms, and integrity checks to prevent unauthorized access or data breaches.
- At the same time, the SRA should prioritize user experience, providing an intuitive and efficient interface for healthcare professionals to access and update patient records.
- It should support various devices and platforms to enable access from different locations and facilitate seamless collaboration among healthcare teams. This integration ensures a comprehensive view of patient information and promotes efficient workflows for healthcare providers.

Question 2: "Is an SRA centered on privacy and security a viable strategy for tackling the challenges associated with ensuring the security and privacy of these systems?"

By incorporating privacy and security considerations into the SRA, several benefits can be achieved:

- Risk mitigation: A well-defined architecture that addresses privacy and security concerns can help identify potential vulnerabilities and risks in the system. It allows for the implementation of appropriate security controls and measures to mitigate these risks effectively.
- Compliance with regulations: Many countries have stringent regulations to protect patient privacy and ensure health data security. Designing an architecture that aligns with these regulations, such as GDPR in Europe, HIPAA in EUA, or LGPD in Brazil, helps healthcare organizations meet legal requirements and avoid penalties or legal consequences.
- Confidentiality and data integrity: Privacy-focused architecture ensures that patient data remains confidential and only accessible to authorized individuals. It includes mechanisms such as access control, emergency access, anonymization, consent, tampering, and data loss.

TABLE 5. Columns and fields of privacy requirements traceability matrix.

ID	A unique ID number is used to identify the traceability item in the requirements traceability matrix.
Associated ID(s)	This column should contain the ID of any associated utilities used for requirements tracking, such as a repository, pipeline document, and so on.
Requirement	This column must be completed with a requirement analysis in the e-SUS PEC.
Category	This column must be filled with requirements about privacy or security, or even if it meets both.
Software Module(s)	This column must be filled in with the name of the correspondent of the module where the analysis was carried out in the e-SUS PEC.
Result	This column should be filled in with a description of the software checking for the privacy or security requirement and whether it was met or not met.
Additional Comments	This column must be filled in with detailed information from the analysis performed on the privacy requirements in the e-SUS PEC.

- **Trust and patient confidence:** When patients trust that their health data is secure and their privacy is protected, they are more likely to actively participate in their own healthcare. An SRA that prioritizes privacy and security helps build trust among patients and encourages them to share accurate and complete information with their healthcare providers.
- **Long-term sustainability:** Considering privacy and security from the outset when designing the architecture ensures that these aspects are embedded into the system's foundation. This approach reduces the risk of security vulnerabilities emerging as an afterthought and promotes the long-term sustainability of the EHR system.

After several studies and applications in the health domain, we designed a robust and usable SRA focusing on EHRs. We also carried out a case study on public EHRs used in Brazil. Brazil has 5568 cities and 44,000 UBS spread across the country [90]. Therefore, regarding the use of e-SUS PEC in Brazil, in terms of percentage, 40% of Brazilian municipalities use e-SUS PEC in their UBS [84]. This reaffirms the dimension of the use of this system in Brazil. Hence, a meaningful way to improve the security and privacy of these systems.

In our case study, we can see that several requirements are not met in the e-SUS PEC. Requirements such as emergency access, anonymization, and integrity were unmet. Therefore, it makes the system vulnerable and makes it easy to expose sensitive patient data. In addition, in our study, if the developers had used the SRA in their development, there is no doubt that requirements like this would not fail to be part of the e-SUS PEC.

VII. CONCLUSION

This study shows that the existing SRAs are still very generic. A few SRAs are focused on EHRs and do not

offer standard privacy and security requirements for EHRs. Therefore, we proposed an SRA focused on EHRs. We show the suitability to evaluate an EHR maintained and managed by the Brazilian government. Our method of evaluating an SRA was successful in a case study. In our future work, we will use this SRA to a greater extent and apply it to other healthcare systems.

In conclusion, an SRA for EHRs that addresses privacy and security is vital to protect patient information, ensure compliance with regulations, build trust, and provide a solid foundation for a secure, privacy-aware healthcare ecosystem.

Declaration of Competing Interest

Competing Interests: The authors declare that they have no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

Ethical Approval: Not Applicable.

ACKNOWLEDGMENT

To conduct tests on the e-SUS PEC system, authorization and access to records from primary health units and the entire healthcare team in the Municipality of Mossoró, Rio Grande do Norte, Brazil, were required. The Municipal Secretary of Health provided the data through an agreement with the Federal Institute of Education, Science, and Technology of Rio Grande do Norte for research purposes. These data were essential for conducting tests in a real-world environment.

AUTHOR'S CONTRIBUTIONS

RT was responsible for the study design and writing of the manuscript. Also, performed the computational analysis on e-SUS PEC. NI made substantial contributions to the conception and design of the article, wrote some parts of the manuscript, reviewed the final manuscript, provided technical support and advice, and critically revised the final article. HM revised the article.

REFERENCES

- [1] *Health Informatics—Electronic Health Record Definition, Scope, and Context*, Standard 20514, 2005. [Online]. Available: <https://www.iso.org/standard/39525.html>
- [2] K. Hayrinen, K. Saranto, and P. Nykanen, "Definition, structure, content, use and impacts of electronic health records: A review of the research literature," *Int. J. Med. Informat.*, vol. 77, no. 5, pp. 291–304, May 2008. [Online]. Available: <http://www.sciencedirect.com/science/article/pii/S1386505607001682>
- [3] A. Ghazvini and Z. Shukur, "Security challenges and success factors of electronic healthcare system," *Proc. Technol.*, vol. 11, pp. 212–219, Jan. 2013. [Online]. Available: <http://www.sciencedirect.com/science/article/pii/S221201731300337X>
- [4] L. Garcés, S. Martínez-Fernández, L. Oliveira, P. Valle, C. Ayala, X. Franch, and E. Y. Nakagawa, "Three decades of software reference architectures: A systematic mapping study," *J. Syst. Softw.*, vol. 179, Sep. 2021, Art. no. 111004.
- [5] R. S. Evans, "Electronic health records: Then, now, and in the future," *Yearbook Med. Informat.*, vol. 25, no. S 1, pp. 48–61, 2016.
- [6] M. Wazid, A. K. Das, N. Kumar, M. Conti, and A. V. Vasilakos, "A novel authentication and key agreement scheme for implantable medical devices deployment," *IEEE J. Biomed. Health Informat.*, vol. 22, no. 4, pp. 1299–1309, Jul. 2018.

- [7] H. M. Hussien, S. M. Yasin, S. N. I. Udzir, A. A. Zaidan, and B. B. Zaidan, "A systematic review for enabling of develop a blockchain technology in healthcare application: Taxonomy, substantially analysis, motivations, challenges, recommendations and future direction," *J. Med. Syst.*, vol. 43, no. 10, p. 320, Sep. 2019, doi: [10.1007/s10916-019-1445-8](https://doi.org/10.1007/s10916-019-1445-8).
- [8] B. F. Smaradottir, "Security management in electronic health records: Attitudes and experiences among health care professionals," in *Proc. Int. Conf. Comput. Sci. Comput. Intell. (CSCI)*, Dec. 2018, pp. 715–719.
- [9] B. Yüksel, A. Küpçü, and Ö. Özkasap, "Research issues for privacy and security of electronic health services," *Future Gener. Comput. Syst.*, vol. 68, pp. 1–13, Mar. 2017. [Online]. Available: <http://www.sciencedirect.com/science/article/pii/S0167739X16302667>
- [10] R. Tertulino, N. Antunes, and H. Morais, "Privacy in electronic health records: A systematic mapping study," *J. Public Health*, vol. 32, no. 3, pp. 435–454, Jan. 2023, doi: [10.1007/s10389-022-01795-z](https://doi.org/10.1007/s10389-022-01795-z).
- [11] S. Martínez-Fernández, C. P. Ayala, X. Franch, and H. M. Marques, "Benefits and drawbacks of software reference architectures: A case study," *Inf. Softw. Technol.*, vol. 88, pp. 37–52, Aug. 2017.
- [12] J. Tummers, H. Tobí, C. Catal, and B. Tekinerdogan, "Designing a reference architecture for health information systems," *BMC Med. Informat. Decis. Making*, vol. 21, no. 1, pp. 1–14, Dec. 2021, doi: [10.1186/s12911-021-01570-2](https://doi.org/10.1186/s12911-021-01570-2).
- [13] E. M. Grua, M. De Sanctis, and P. Lago, "A reference architecture for personalized and self-adaptive e-health apps," in *Proc. Eur. Conf. Softw. Archit.* Springer, 2020, pp. 195–209, doi: [10.1007/978-3-030-59155-7_15](https://doi.org/10.1007/978-3-030-59155-7_15).
- [14] I. D. M. B. Filho and G. S. D. A. Junior, "A software reference architecture for iot-based healthcare applications," in *Proc. 18th Int. Conf.*, Melbourne, VIC, Australia. Springer, Jul. 2018, pp. 173–188, doi: [10.1007/978-3-319-95171-3_15](https://doi.org/10.1007/978-3-319-95171-3_15).
- [15] G. A. Attwell, K. E. Bennin, and B. Tekinerdogan, "Reference architecture design for computer-based speech therapy systems," *Comput. Speech Lang.*, vol. 78, Mar. 2023, Art. no. 101465.
- [16] C. Kalloniatis, E. Kavakli, and S. Gritzalis, "Addressing privacy requirements in system design: The PriS method," *Requirements Eng.*, vol. 13, no. 3, pp. 241–255, Sep. 2008.
- [17] T. McQuay and A. Cavoukian, "A pragmatic approach to privacy risk optimization: Privacy by design for business practices," *Identity Inf. Soc.*, vol. 3, no. 2, pp. 379–396, Aug. 2010.
- [18] A. Cavoukian, "Understanding how to implement privacy by design, one step at a time," *IEEE Consum. Electron. Mag.*, vol. 9, no. 2, pp. 78–82, Mar. 2020.
- [19] F. H. Semantha, S. Azam, K. C. Yeo, and B. Shanmugam, "A systematic literature review on privacy by design in the healthcare sector," *Electronics*, vol. 9, no. 3, p. 452, Mar. 2020.
- [20] A. Hosseini, H. Emami, Y. Sadat, and S. Paydar, "Integrated personal health record (PHR) security: Requirements and mechanisms," *BMC Med. Informat. Decis. Making*, vol. 23, no. 1, p. 116, Jul. 2023, doi: [10.1186/s12911-023-02225-0](https://doi.org/10.1186/s12911-023-02225-0).
- [21] F. A. Reegu, H. Abas, Y. Gulzar, Q. Xin, A. A. Alwan, A. Jabbari, R. G. Sonkamble, and R. A. Dziyaiddin, "Blockchain-based framework for interoperable electronic health records for an improved healthcare system," *Sustainability*, vol. 15, no. 8, p. 6337, Apr. 2023. [Online]. Available: <https://www.mdpi.com/2071-1050/15/8/6337>
- [22] I. Keshta and A. Odeh, "Security and privacy of electronic health records: Concerns and challenges," *Egyptian Informat. J.*, vol. 22, no. 2, pp. 177–183, Jul. 2021.
- [23] L. O. Nweke, P. Yeng, S. D., and B. Yang, "Understanding attribute-based access control for modelling and analysing healthcare professionals' security practices," *Int. J. Adv. Comput. Sci. Appl.*, vol. 11, no. 2, pp. 683–690, 2020.
- [24] K. Edemacu, H. K. Park, B. Jang, and J. W. Kim, "Privacy provision in collaborative ehealth with attribute-based encryption: Survey, challenges and future directions," *IEEE Access*, vol. 7, pp. 89614–89636, 2019.
- [25] Q. Mamun and M. Rana, "A robust authentication model using multi-channel communication for eHealth systems to enhance privacy and security," in *Proc. 8th IEEE Annu. Inf. Technol., Electron. Mobile Commun. Conf. (IEMCON)*, Oct. 2017, pp. 255–260.
- [26] R. Priya, S. Sivasankaran, P. Ravisasthithi, and S. Sivachandiran, "A survey on security attacks in electronic healthcare systems," in *Proc. Int. Conf. Commun. Signal Process. (ICCSPP)*, Apr. 2017, pp. 0691–0694.
- [27] S. Banerjee, S. Barik, D. Das, and U. Ghosh, "EHR security and privacy aspects: A systematic review," in *Proc. IFIP Int. Internet Things Conf.* Switzerland: Springer, 2023, pp. 243–260, doi: [10.1007/978-3-031-45878-1_17](https://doi.org/10.1007/978-3-031-45878-1_17).
- [28] J. J. Hathaliya and S. Tanwar, "An exhaustive survey on security and privacy issues in healthcare 4.0," *Comput. Commun.*, vol. 153, pp. 311–335, Mar. 2020. [Online]. Available: <http://www.sciencedirect.com/science/article/pii/S0140366419311880>
- [29] M. Zarour, M. Alenezi, M. T. J. Ansari, A. K. Pandey, M. Ahmad, A. Agrawal, R. Kumar, and R. A. Khan, "Ensuring data integrity of healthcare information in the era of digital health," *Healthcare Technol. Lett.*, vol. 8, no. 3, pp. 66–77, Jun. 2021.
- [30] J. L. Fernández-Alemán, I. C. Señor, P. Á. O. Lozoya, and A. Toval, "Security and privacy in electronic health records: A systematic literature review," *J. Biomed. Informat.*, vol. 46, no. 3, pp. 541–562, Jun. 2013. [Online]. Available: <http://www.sciencedirect.com/science/article/pii/S1532046412001864>
- [31] O. El-Gayar and A. Elnoshokaty, "Factors and design features influencing the continued use of wearable devices," *J. Healthcare Informat. Res.*, vol. 7, no. 3, pp. 359–385, Sep. 2023, doi: [10.1007/s41666-023-00135-4](https://doi.org/10.1007/s41666-023-00135-4).
- [32] L. Bass, P. Clements, and R. Kazman, *Software Architecture in Practice*. Reading, MA, USA: Addison-Wesley, 2021.
- [33] N. Ford, R. Parsons, P. Kua, and P. Sadalage, *Building Evolutionary Architectures*. Newton, MA, USA: O'Reilly Media, 2022. [Online]. Available: <https://books.google.pt/books?id=BmudEAAQBAJ>
- [34] P. Clements, F. Bachmann, L. Bass, D. Garlan, J. Ivers, R. Little, P. Merson, R. Nord, and J. Stafford, *Documenting Software Architectures: Views and Beyond* (SEI Series in Software Engineering). London, U.K.: Pearson, 2010. [Online]. Available: <https://books.google.com.br/books?id=UTZbsrA4qAsC>
- [35] M. D. Brodney, G. Bakken, C. R. Butler, J. Klug-McLeod, R. Owen, and S. Sng, "Integrated design environment: A multi-use platform for design idea capture, evaluation, and tracking in medicinal chemistry," *J. Comput. Chem.*, vol. 44, no. 6, pp. 788–800, Mar. 2023.
- [36] V. Khononov, *Learning Domain-Driven Design: Aligning Software Architecture and Business Strategy*. Newton, MA, USA: O'Reilly Media, 2021. [Online]. Available: <https://books.google.pt/books?id=jSVhzgEACAAJ>
- [37] M. A. Chauhan, M. A. Babar, and C. W. Probst, "A process framework for designing software reference architectures for providing tools as a service," in *Product-Focused Software Process Improvement*, P. Abrahamsson, A. Jedlitschka, A. N. Duc, M. Felderer, S. Amasaki, and T. Mikkonen, Eds., Cham, Switzerland: Springer, 2016, pp. 111–126.
- [38] A. López Martínez, M. Gil Pérez, and A. Ruiz-Martínez, "A comprehensive review of the state-of-the-art on security and privacy issues in healthcare," *ACM Comput. Surveys*, vol. 55, no. 12, pp. 1–38, Mar. 2023, doi: [10.1145/3571156](https://doi.org/10.1145/3571156).
- [39] I. Governance. (2018). *Preparing for the EU GDPR in Research Settings/Guidance*. Accessed: Oct. 13, 2022. [Online]. Available: <https://www.itgovernance.eu/en-ie/eu-general-data-protection-regulation-gdpr-ie>
- [40] UD Health & Human Services. (2013). *Summary of the HIPAA Privacy Rule*. [Online]. Available: <https://www.hhs.gov/sites/default/files/ocr/privacy/hipaa/understanding/summary/privacysummary.pdf>
- [41] A. Fatima and R. Colomo-Palacios, "Security aspects in healthcare information systems: A systematic mapping," *Proc. Comput. Sci.*, vol. 138, pp. 12–19, Jan. 2018.
- [42] ISO. (2011). *Health Informatics—Requirements for an Electronic Health Record Architecture*. [Online]. Available: <https://www.iso.org/standard/52823.html>
- [43] S. Angelov, P. Grefen, and D. Greefhorst, "A classification of software reference architectures: Analyzing their success and effectiveness," in *Proc. Joint Working IEEE/IFIP Conf. Softw. Architecture Eur. Conf. Softw. Architecture*, Sep. 2009, pp. 141–150.
- [44] S. Angelov, P. Grefen, and D. Greefhorst, "A framework for analysis and design of software reference architectures," *Inf. Softw. Technol.*, vol. 54, no. 4, pp. 417–431, Apr. 2012. [Online]. Available: <https://www.sciencedirect.com/science/article/pii/S095050584911002333>
- [45] D. Garlan and B. Schmerl, "Architecture-driven modelling and analysis," in *Proc. ACM Int. Conf.*, vol. 248, 2007, pp. 3–17.
- [46] Z. Qin, X. Zheng, and J. Xing, "Introduction to software architecture," in *Software Architecture. Advanced Topics in Science and Technology in China*. Berlin, Germany: Springer, 2008, pp. 1–33, doi: [10.1007/978-3-540-74343-9_1](https://doi.org/10.1007/978-3-540-74343-9_1).

- [47] N. M. Shrestha, A. Alsadoon, P. W. C. Prasad, L. Hourany, and A. Elchouemi, "Enhanced e-health framework for security and privacy in healthcare system," in *Proc. 6th Int. Conf. Digit. Inf. Process. Commun. (ICDIPC)*, Apr. 2016, pp. 75–79.
- [48] P. Gope and R. Amin, "A novel reference security model with the situation based access policy for accessing EPHR data," *J. Med. Syst.*, vol. 40, no. 11, p. 242, Sep. 2016, doi: [10.1007/s10916-016-0620-4](https://doi.org/10.1007/s10916-016-0620-4).
- [49] Y.-N. Shin, "Standard implementation for privacy framework and privacy reference architecture for protecting personally identifiable information," *Int. J. Fuzzy Log. Intell. Syst.*, vol. 11, no. 3, pp. 197–203, Sep. 2011.
- [50] M. Gharib, M. Salnitri, E. Paja, P. Giorgini, H. Mouratidis, M. Pavlidis, J. F. Ruiz, S. Fernandez, and A. D. Siria, "Privacy requirements: Findings and lessons learned in developing a privacy platform," in *Proc. IEEE 24th Int. Requirements Eng. Conf. (RE)*, Sep. 2016, pp. 256–265.
- [51] B. Tekinerdogan and K. Öztürk, "Feature-driven design of SaaS architectures," in *Software Engineering Frameworks for the Cloud Computing Paradigm* (Computer Communications and Networks), Z. Mahmood and S. Saeed, Eds. London, U.K.: Springer, 2013, doi: [10.1007/978-1-4471-5031-2_9](https://doi.org/10.1007/978-1-4471-5031-2_9).
- [52] A. Ibrahim and M. Singhal, "An abstract architecture design for medical information exchange," in *Proc. Int. Conf. Ind. Informat. Comput. Syst. (CIICS)*, Mar. 2016, pp. 1–6.
- [53] Y. Sharma and B. Balamurugan, "Preserving the privacy of electronic health records using blockchain," *Proc. Comput. Sci.*, vol. 173, pp. 171–180, Jan. 2020. [Online]. Available: <http://www.sciencedirect.com/science/article/pii/S1877050920315258>
- [54] X. Guo, G. Zhang, and Y. Zhang, "A comprehensive review of blockchain technology-enabled smart manufacturing: A framework, challenges and future research directions," *Sensors*, vol. 23, no. 1, p. 155, Dec. 2022. [Online]. Available: <https://www.mdpi.com/1424-8220/23/1/155>
- [55] D. Sahu, N. Tiwari, and M. Chawla, "Blockchain as a solution for electronic health record management: A comprehensive review," in *Proc. IEEE Int. Students' Conf. Electr. Electron. Comput. Sci. (SCEECs)*, Feb. 2024, pp. 1–6. [Online]. Available: <https://www.scopus.com/inward/record.uri?eid=2-s2.0-85190535070&doi=10.1109%2FSCEECs61402.2024.10482149&partnerID=40&md5=158c5a65baae92c29407bf2fbc127ef7>
- [56] L. Ismail and H. Materwala, "BlockHR: A blockchain-based framework for health records management," in *Proc. 12th Int. Conf. Comput. Model. Simul.* New York, NY, USA: Association for Computing Machinery, Jun. 2020, pp. 164–168, doi: [10.1145/3408066.3408106](https://doi.org/10.1145/3408066.3408106).
- [57] M. Farhadi, H. Haddad, and H. Shahriar, "Compliance checking of open source EHR applications for HIPAA and ONC security and privacy requirements," in *Proc. IEEE 43rd Annu. Comput. Softw. Appl. Conf. (COMPSAC)*, vol. 1, Jul. 2019, pp. 704–713.
- [58] R. Xu, J. Joshi, and P. Krishnamurthy, "An integrated privacy preserving attribute-based access control framework supporting secure deduplication," *IEEE Trans. Dependable Secure Comput.*, vol. 18, no. 2, pp. 706–721, Mar. 2021.
- [59] Y. M. Essa, E. E.-D. Hemdan, A. El-Mahalawy, G. Attiya, and A. El-Sayed, "IFHDS: Intelligent framework for securing healthcare BigData," *J. Med. Syst.*, vol. 43, no. 5, p. 124, Mar. 2019, doi: [10.1007/s10916-019-1250-4](https://doi.org/10.1007/s10916-019-1250-4).
- [60] M. Abomhara, G. M. Kojien, V. A. Oleshchuk, and M. Hamid, "Towards risk-aware access control framework for healthcare information sharing," in *Proc. 4th Int. Conf. Inf. Syst. Secur. Privacy*, 2018, pp. 312–321.
- [61] M. E. Rana and M. Jayabalan, "Privacy preserving anonymization techniques for patient data: An overview," in *Proc. 3rd Int. Conf. Knowl., Inf. Softw. Eng. (ICKIS)*, Jan. 2016, pp. 1–4.
- [62] J. Eom, D. H. Lee, and K. Lee, "Patient-controlled attribute-based encryption for secure electronic health records system," *J. Med. Syst.*, vol. 40, no. 12, p. 253, Dec. 2016.
- [63] B. Fung, K. Wang, A. W.-C. Fu, and P. S. Yu, *An Introduction To Privacy-Preserving Data Publishing: Concepts and Techniques*. Boca Raton, FL, USA: CRC Press, 2010.
- [64] K. E. Emam and L. Arbuckle, *Anonymizing Health Data: Case Studies and Methods to Get You Started*. Newton, MA, USA: O'Reilly Media, 2013.
- [65] A. K. Sangaiah, A. Javadpour, F. Ja'fari, P. Pinto, and H.-M. Chuang, "Privacy-aware and AI techniques for healthcare based on K-anonymity model in Internet of Things," *IEEE Trans. Eng. Manag.*, vol. 71, pp. 12448–12462, 2023.
- [66] H. Zhu, S. Tian, and K. Lü, "Privacy-preserving data publication with features of independent 1-Diversity," *Comput. J.*, vol. 58, no. 4, pp. 549–571, Apr. 2015.
- [67] G. Hao and X. Ya-Bin, "Research on privacy preserving method based on T-closeness model," in *Proc. 3rd IEEE Int. Conf. Comput. Commun. (ICCC)*, Dec. 2017, pp. 1455–1459.
- [68] A. Zhang, A. Bacchus, and X. Lin, "Consent-based access control for secure and privacy-preserving health information exchange," *Secur. Commun. Netw.*, vol. 9, no. 16, pp. 3496–3508, Nov. 2016. [Online]. Available: <https://onlinelibrary.wiley.com/doi/abs/10.1002/sec.1556>
- [69] I. Mistrik, M. Galster, and B. Maxim, *Software Engineering for Variability Intensive Systems: Foundations and Applications*. Boca Raton, FL, USA: CRC Press, 2019. [Online]. Available: <https://books.google.com.br/books?id=uPSDDwAAQBAJ>
- [70] Á. Mora Segura, J. de Lara, and M. Wimmer, "Modelling assistants based on information reuse: A user evaluation for language engineering," *Softw. Syst. Model.*, vol. 23, no. 1, pp. 57–84, Feb. 2024.
- [71] G. Hohpe and B. Woolf, *Enterprise Integration Patterns: Designing, Building, and Deploying Messaging Solutions*. Reading, MA, USA: Addison-Wesley, 2004. [Online]. Available: <https://books.google.com.br/books?id=bUlsAQAAQBAJ>
- [72] *A Guide to the Project Management Body of Knowledge (PMBOK (R) Guide) A Guide to the Project Management Body of Knowledge (PMBOK (R) Guide)*, 7th ed., Project Manag. Inst., Newton Square, PA, USA, Aug. 2022.
- [73] GDPR. (2016). *Regulation (EU) 2016/679 of the European Parliament and of the Council of 27, April 2016 on the Protection of Natural Persons With Regard to the Processing of Personal Data and on the Free Movement of Such Data, and Repealing Directive 95/46/EC (General Data Protection Regulation)*. [Online]. Available: https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=uriserv:OJ.L_.2016.119.01.0001.01.ENG&toc=OJ.L.2016.119:TOC
- [74] R. Hussein, D. Wurhofer, E.-M. Strumegger, A. Stainer-Hochgatterer, S. T. Kulnik, R. Crutzen, and J. Niebauer, "General data protection regulation (GDPR) toolkit for digital health," *Stud. Health Technol. Informat.*, vol. 290, pp. 222–226, Jan. 2022. [Online]. Available: <https://www.scopus.com/inward/record.uri?eid=2-s2.0-85131469049&doi=10.3233%2FSHTI220066&partnerID=40&md5=2347ee749061439f7a8561af6a16f178>
- [75] R. Clarke, "Privacy impact assessment: Its origins and development," *Comput. Law Secur. Rev.*, vol. 25, no. 2, pp. 123–135, Jan. 2009. [Online]. Available: <https://www.sciencedirect.com/science/article/pii/S0267364909000302>
- [76] D. Papamartzivanos, S. A. Menesidou, P. Gouvas, and T. Giannetsos, "A perfect match: Converging and automating privacy and security impact assessment on-the-fly," *Future Internet*, vol. 13, no. 2, p. 30, Jan. 2021. [Online]. Available: <https://www.mdpi.com/1999-5903/13/2/30>
- [77] H. Van Vliet, H. Van Vliet, and J. Van Vliet, *Software Engineering: Principles and Practice*. Hoboken, NJ, USA: Wiley, 2008, vol. 13.
- [78] J. Melegati and X. Wang, "Case survey studies in software engineering research," in *Proc. 14th ACM/IEEE Int. Symp. Empirical Softw. Eng. Meas. (ESEM)*, Oct. 2020, pp. 1–12. [Online]. Available: <https://api.semanticscholar.org/CorpusID:220793840>
- [79] P. Runeson and M. Höst, "Guidelines for conducting and reporting case study research in software engineering," *Empirical Softw. Eng.*, vol. 14, no. 2, pp. 131–164, Apr. 2009, doi: [10.1007/s10664-008-9102-8](https://doi.org/10.1007/s10664-008-9102-8).
- [80] J. M. S. Ricci, A. L. Z. Romito, S. A. D. Silva, A. A. F. Carioca, and B. H. Lourenço, "Marcadores do consumo alimentar do sisvan: Tendência temporal da cobertura e integração com o e-SUS APS, 2015–2019," *Ciência Saúde Coletiva*, vol. 28, no. 3, pp. 921–934, Mar. 2023, doi: [10.1590/1413-81232023283.10552022](https://doi.org/10.1590/1413-81232023283.10552022).
- [81] Ministério da Saúde. (2023). *Prontuário eletrônico do cidadão v5.0—Instalação do Sistema*. Disponível. Accessed: Jun. 12, 2023. [Online]. Available: <https://saps-ms.github.io/Manual-eSUS-APS/docs/PEC/PEC-02-instalacao/>
- [82] L. Postal, I. C. Celuppi, G. D. S. Lima, M. Felisberto, T. C. Lacerda, R. S. Wazlawick, and E. M. Dalmarco, "PEC e-SUS APS online appointment scheduling system: A tool to facilitate access to primary care in Brazil," *Cien. Saude Colet.*, vol. 26, no. 6, pp. 2023–2034, Jun. 2021.
- [83] Ministério da Saúde. (2023). *Ministério Da Saúde/Secretaria de Atenção Primária à Saúde*. Disponível. Accessed: Feb. 13, 2023. [Online]. Available: <https://github.com/SAPS-MS/Manual-eSUSAPS>
- [84] T. C. Lacerda, J. F. Hammes, M. Fantonelli, E. M. Dalmarco, and R. S. Wazlawick, "e-SUS APS strategy: Case of success on primary care informatization in Brazil," *J. Health Informat.*, vol. 12, no. 4, pp. 138–143, Nov. 2020. [Online]. Available: <https://jhi.sbis.org.br/index.php/jhi-sbis/article/view/754>

- [85] M. Madan, M. Dave, and A. Tandon, "Importance of RTM for testing a web-based project," in *Proc. 7th Int. Conf. Rel., INFOCOM Technol. Optim.*, Aug. 2018, pp. 816–818.
- [86] O. C. Z. Gotel and C. W. Finkelstein, "An analysis of the requirements traceability problem," in *Proc. IEEE Int. Conf. Requirements Eng.*, Sep. 1994, pp. 94–101.
- [87] P. U. Hatipoglu, A. Atvar, Y. O. Artan, O. Sereflisan, and A. Demir, "Software requirement traceability analysis using text mining methods," in *Proc. 25th Signal Process. Commun. Appl. Conf. (SIU)*, May 2017, pp. 1–4.
- [88] S. Jeong, H. Cho, and S. Lee, "Agile requirement traceability matrix," in *Proc. IEEE/ACM 40th Int. Conf. Softw. Eng., Companion (ICSE-Companion)*. New York, NY, USA: Association for Computing Machinery, May 2018, pp. 187–188.
- [89] B. Wang, R. Peng, Y. Li, H. Lai, and Z. Wang, "Requirements traceability technologies and technology transfer decision support: A systematic review," *J. Syst. Softw.*, vol. 146, pp. 59–79, Dec. 2018. [Online]. Available: <https://www.sciencedirect.com/science/article/pii/S0164121218301754>
- [90] IBGE. *Instituto Brasileiro De Geografia E Estatística*. Accessed: Jun. 18, 2023. [Online]. Available: <https://censo2022.ibge.gov.br/>



applied to healthcare (EHR) systems.

RODRIGO TERTULINO is currently pursuing the Ph.D. degree with the Department of Informatics and Engineering, University of Coimbra (UC). He is part of the Security Software Group (SSE), Centre for Informatics and Systems of the University of Coimbra (CISUC). He is also an Associate Professor with the Federal Institute of Education, Science, and Technology of Rio Grande do Norte (IFRN), Brazil. His research interests include privacy, security, and blockchain



safety assessment of computer systems. In her field of specialization, she has authored more than 45 peer-reviewed publications and participated in several national and international research projects.

NAGHMEH IVAKI (Member, IEEE) received the Ph.D. degree from the University of Coimbra, Portugal. Currently, she is an Assistant Professor and a Full Member of the Software and Systems Engineering Group (SSE), Centre for Informatics and Systems of the University of Coimbra (CISUC), Department of Informatics Engineering, University of Coimbra. She specializes in the scientific field of informatics engineering, with a particular focus on the dependability, security, and



especially in software architecture, electronic health records (EHR), and information systems for public health. Besides, he is interested in developing biomedical devices for the early diagnosis of cancer.

HIGOR MORAIS received the Ph.D. degree in electrical and computing engineering from the Federal University of Rio Grande do Norte, in 2015. He has been a State Coordinator with the Telehealth Center of Rio Grande do Norte, since 2018. He is currently an Associate Professor of information systems area with the Federal Institute of Education, Science, and Technology of Rio Grande do Norte (IFRN). His main interests include the academic area is digital health,

...